PORTFOLIO GRC CYBER

Évaluation des risques cyber et des contrôles SSI

Atlas Services | Tanger | PME fictive

Anas El Karkouri
Étudiant ingénieur, 5e année - EMSI Tanger

Version finale 1.2 - 7 octobre 2026

Étude de cas pédagogique : organisations, pièces E/V et décisions simulées. Les annexes décrivent les opérations réelles effectuées sur le laboratoire personnel avec assistance Codex. Aucun test personnel ne clôture une action du cas.

Document de travail. Référentiels ISO étudiés à partir de fiches publiques ; textes complets sous licence non fournis. Aucune certification ni audit formel revendiqué.

Organisation du dossier

1. Projet 1 - Synthèse pour la direction
2. Projet 1 - Contexte, périmètre SSI et actifs
3. Projet 1 - Méthode et registre des risques
4. Projet 1 - Traitement, mesures et extrait de SoA
5. Projet 1 - Justificatifs et constats documentaires
6. Projet 1 - PSSI et procédures proposées
7. Protocoles des tests et observation historique
8. Projet 1 - Profil actuel et cible NIST CSF 2.0
9. Inventaire du laboratoire et modifications
10. T01 Habilitations MFA et sessions
11. T02 Événement collecte et SIEM
12. T03 Sauvegarde et restauration de fichiers
13. T04 Marqueur Git historique et accès locaux
14. Matrice des preuves et traçabilité
15. Sources et limites de vérification

Les tableaux larges sont présentés par entrée pour garder chaque champ lisible. Les références de pièces renvoient aux fichiers du portfolio fourni. Les preuves assainies et leurs empreintes sont accessibles dans Annexes_laboratoire.

Source éditable : Projet_1_SSI/08_synthese_direction.md

Projet 1 - Synthèse pour la direction

Évaluation des risques cyber et des contrôles SSI Atlas Services - entreprise fictive Version 1.0 - situation simulée au 7 octobre 2026

Décision proposée

Prioriser la protection des accès privilégiés, la réaction à l'exposition d'un secret, la restaurabilité des sauvegardes et le chiffrement du poste identifié. Maintenir le fournisseur SaaS hors production jusqu'à la levée des conditions du projet 2.

La direction fictive reçoit une évaluation documentaire renseignée. Les mesures proposées de la PME restent non exécutées. Les trois tests personnels T01/T03/T04 et le parcours partiel T02 sont documentés dans des annexes distinctes, sans effet automatique sur les cotations du cas.

Résultats principaux

Le registre comprend douze risques : **cinq critiques, cinq élevés et deux modérés**. R08 est prospectif et concerne le SaaS avant production. Les onze risques liés aux activités existantes comprennent quatre critiques, cinq élevés et deux modérés.

Ces niveaux sont des jugements du cas, pas des fréquences mesurées. R03 et R11 comportent des hypothèses prudentes à valider ; la méthode documente une variante de cotation et son effet sur les priorités.

Le dossier examine dix actifs et huit constats documentaires. Les principaux écarts du scénario portent sur les comptes privilégiés, un secret exposé, un compte de départ encore actif, un poste non chiffré et un changement sans approbation.

La présence de sauvegardes est déclarée, mais leur restauration n'est pas démontrée. Le SIEM montre un signal sur une partie du périmètre ; la couverture et l'efficacité durable restent limitées.

Le registre prévoit trois risques faibles et neuf modérés **à l'état cible conditionnel**. Cette répartition n'est pas une amélioration déjà obtenue.

Priorités

Échéance proposée	Décision et action	Responsables
8 octobre, J+1	Invalider le secret du scénario et retirer l'accès de départ	RD, RI, RH
9 octobre, J+2	Réduire l'exposition des comptes privilégiés et du poste non chiffré ; protéger la reprise	RI
17 octobre, J+10	Corriger et faire valider la faiblesse applicative locale	RD
22 octobre, J+15	Obtenir une restauration documentée et une vision du parc	RI et RS
6 novembre, J+30	Étendre surveillance, sensibilisation, exports et maîtrise des changements	RI, RS, RD
6 décembre, J+60	Exercer la suppléance et la reprise documentaire	RI
Avant production SaaS	Lever les blocages fournisseur et obtenir les validations de sécurité et de données	RS, RSSI, RJ, DG

Indicateurs proposés

Ces indicateurs sont locaux. Les valeurs actuelles sont limitées aux pièces simulées disponibles.

Indicateur	Valeur actuelle du cas	Cible	Limite et source
Comptes privilégiés avec MFA imposé	1 sur 3	3 sur 3, ou exception maîtrisée et approuvée	E02 ; configuration, pas test de fonctionnement
Sources prioritaires déclarées couvertes	2 sur 6	6 sur 6 ou exclusions justifiées	E03 ; pertinence et qualité de collecte à examiner
Rapports de restauration fournis	0	Un test du service et une revue périodique	E04 ; absence de preuve, pas preuve d'échec
Postes chiffrés dans l'échantillon	2 sur 3	3 sur 3, puis couverture du parc vérifiée	E06 ; aucune extrapolation aux 40
Actions M01 à M12 clôturées avec preuve	0 sur 12	Clôture progressive à l'échéance	Plan proposé, aucune exécution déclarée
Tests personnels exécutés	4 sur 4 exécutés ; trois réussites bornées, un partiel	Conservation et couverture T02 à approfondir	Annexes réelles ; ne modifie pas les indicateurs E02/E03/E04

Ne pas présenter ces fractions comme un taux de conformité ISO.

Arbitrages à obtenir

- Valider le périmètre et les propriétaires des actifs et risques.
- Confirmer avec le support les objectifs de reprise huit heures/24 heures.

- Affecter ressources et suppléance aux actions.
- Approuver PSSI, méthode et processus d'exception.
- Décider du maintien du pilote SaaS avec données artificielles et des conditions de production.

Assurance et limites

Cette étude montre le chemin entre actifs, scénarios, justificatifs, constats, traitement et décision. Les sources de l'entreprise sont fictives. L'efficacité réelle des contrôles n'est pas attestée. L'extrait de SoA porte sur vingt mesures et le profil NIST sur treize sous-catégories.

La lecture historique du rapport Tanger Med apporte une illustration technique distincte. Elle n'étend pas les conclusions à l'entreprise fictive.

Message à retenir en entretien

« J'ai construit une étude de cas GRC documentée : le périmètre et les actifs conduisent aux scénarios, les preuves conditionnent les constats et les mesures ont des propriétaires et des critères de clôture. Je distingue les documents simulés, les observations historiques de stage et les trois tests de laboratoire prouvés et le parcours SIEM T02 partiel. »

Historique de finalisation

07/10/2026 : annexes personnelles ajoutées ; scores, actions M et décision SaaS de référence inchangés.

Source éditable : Projet_1_SSI/01_contexte_perimetre_actifs.md

Projet 1 - Contexte, périmètre SSI et actifs

Évaluation des risques cyber et des contrôles SSI Cas pédagogique simulé - version 1.0 - 7 octobre 2026

1. Organisation étudiée

Atlas Services - cas pédagogique est une PME fictive de services informatiques installée à Tanger. Ses 40 collaborateurs réalisent du support B2B et du développement applicatif pour des PME. Elle emploie deux administrateurs systèmes, une équipe de développement et un responsable support.

Elle utilise une messagerie, un annuaire, un serveur de tickets local, des postes portables, un dépôt Git privé, des sauvegardes et une instance Wazuh limitée à un périmètre pilote.

Le fournisseur SupportCloud est évalué pour remplacer le serveur de tickets. **Le SaaS est seulement testé avec vingt tickets artificiels. Il n'est pas en production.** Les risques de ce futur usage sont distingués des expositions actuelles.

Toutes les personnes, quantités, configurations et dates d'artefacts de ce cas sont fictives.

2. Objectifs et mandat de l'atelier

La direction fictive demande une évaluation des risques SSI et un premier dossier de gouvernance. Les critères choisis pour l'exercice sont :

- protéger les comptes privilégiés et les informations clients ;
- rétablir le service local de tickets en huit heures, avec au plus 24 heures de données perdues, **objectifs à valider par le métier** ;

- disposer de preuves suffisantes pour les contrôles retenus ;
- décider des conditions de passage en production du SaaS ;
- affecter chaque risque à un responsable et chaque action à un pilote.

L'évaluation porte sur le contexte et des justificatifs documentaires. Elle ne vaut pas autorisation de modifier un système réel, ni audit de certification.

3. Périmètre proposé du SMSI

Déclaration de périmètre de travail

Les activités de support client et de développement applicatif d'Atlas Services, ainsi que les informations, identités, postes, applications, dépôts, sauvegardes et services d'infrastructure qui les soutiennent, sont inclus dans le périmètre proposé. Le projet d'adoption SupportCloud est inclus dans le processus d'évaluation fournisseur. Les systèmes internes du fournisseur ne sont pas administrés ni audités directement par Atlas Services.

Inclus

Support B2B, développement, utilisateurs de ces activités, accès à distance, comptes techniques, application de tickets, dépôt Git, sauvegardes, journalisation et gestion des fournisseurs associés.

Limites et interfaces

La paie et la comptabilité sont hors du périmètre d'analyse détaillée. Leurs interfaces avec l'annuaire, les postes et les comptes partagés restent identifiées. Cette limite pédagogique ne démontre pas qu'elles seraient excluables d'un SMSI réel.

Les infrastructures clientes et les systèmes internes du fournisseur sont des dépendances externes. Aucun test intrusif n'y est autorisé. L'étude fournisseur examine les garanties, documents, interfaces et responsabilités partagées.

Laboratoire technique

Le laboratoire d'Anas, s'il est disponible, est séparé de la PME fictive. Il sert à démontrer des mécanismes avec des comptes et données de test. Un test de laboratoire ne prouve pas l'efficacité globale d'un contrôle dans l'entreprise.

4. Parties intéressées

Partie	Attente SSI retenue	Réponse proposée
Direction	Comprendre les risques et arbitrer les ressources	Registre, propriétaires, priorités et revue mensuelle
Clients B2B	Confidentialité des tickets et continuité du support	Accès limités, engagements, sauvegardes et traitement des incidents
Collaborateurs	Accès nécessaires et consignes compréhensibles	Habilitations nominatives, sensibilisation et canal d'alerte
Administrateurs	Rôles explicites et accès de secours contrôlés	Séparation des comptes, MFA et procédure de récupération
Développeurs	Accès au code et changements traçables	Protection des secrets, revue et validation des déploiements
Fournisseur SaaS	Exigences de sécurité compatibles avec le service acheté	Questionnaire, accord, suivi et plan de sortie
Fonction juridique/protection des données	Informations suffisantes pour qualifier obligations et transferts	Cartographie des données et revue séparée avant production

5. Gouvernance proposée

Rôle fictif	Responsabilité
Direction générale - DG	Approuve le périmètre, les critères, la PSSI et les exceptions importantes
Responsable SSI - RSSI	Coordonne l'analyse, vérifie les preuves et suit le traitement
Responsable infrastructure - RI	Pilote identités, postes, journaux et sauvegardes
Responsable développement - RD	Pilote code, secrets, vulnérabilités et changements
Responsable support - RS	Porte les besoins métier, les données de tickets et le risque fournisseur
RH	Signale les arrivées, changements et départs
Référent juridique/protection des données - RJ	Qualifie les points contractuels et de données personnelles

Le propriétaire d'un risque décide du traitement dans son domaine et rend compte à la direction. Le pilote d'une action réalise la mesure. Le RSSI examine les preuves. Une seule personne peut cumuler des fonctions dans une PME, mais ne doit pas valider seule toutes ses propres actions sensibles.

6. Inventaire de travail

Cet inventaire de dix actifs est **une proposition issue de l'étude**. Les propriétaires restent à valider par les rôles fictifs. Il ne remplace pas l'inventaire initial incomplet E01.

C, I et D expriment les besoins de confidentialité, intégrité et disponibilité sur l'échelle locale 1 à 5. Ils ne constituent pas automatiquement l'impact de chaque scénario.

Lecture du tableau par entrée : tous les champs sont conservés.

ID : A01

Actif et information associée : Annuaire, identités et comptes privilégiés
Propriétaire proposé : RI
C/I/D : 5/5/4
Dépendances ou interfaces : Postes, messagerie, administration
Statut : Existant dans le cas

ID : A02

Actif et information associée : Messagerie et échanges clients
Propriétaire proposé : RS
C/I/D : 4/4/3
Dépendances ou interfaces : Annuaire, Internet, postes
Statut : Existant

ID : A03

Actif et information associée : 40 postes portables
Propriétaire proposé : RI
C/I/D : 4/3/3
Dépendances ou interfaces : Identités, accès distant, chiffrement
Statut : Existant

ID : A04

Actif et information associée : Application locale de tickets et base
Propriétaire proposé : RS
C/I/D : 4/4/5
Dépendances ou interfaces : VM, comptes, sauvegardes
Statut : Existant

ID : A05

Actif et information associée : Dépôt Git privé et code applicatif
Propriétaire proposé : RD
C/I/D : 4/4/3
Dépendances ou interfaces : Identités, revues, secrets
Statut : Existant

ID : A06

Actif et information associée : Sauvegardes du serveur de tickets
Propriétaire proposé : RI
C/I/D : 4/4/5
Dépendances ou interfaces : Stockage séparé, compte de sauvegarde, restauration
Statut : Existant, restaurabilité non démontrée

ID : A07

Actif et information associée : SIEM Wazuh pilote et journaux
Propriétaire proposé : RI
C/I/D : 3/4/3
Dépendances ou interfaces : Sources, agents, heure, stockage
Statut : Existant, couverture limitée

ID : A08

Actif et information associée : SupportCloud et données du futur service
Propriétaire proposé : RS
C/I/D : 4/4/4
Dépendances ou interfaces : Fournisseur, contrats, export, sous-traitants
Statut : Pilote avec données artificielles

ID : A09

Actif et information associée : Documentation d'exploitation et procédures
Propriétaire proposé : RI
C/I/D : 3/4/4
Dépendances ou interfaces : Dépôt documentaire, personnes, accès
Statut : Existant, documentation partielle

ID : A10

Actif et information associée : Exports locaux de tickets et pièces jointes
Propriétaire proposé : RS
C/I/D : 4/3/2
Dépendances ou interfaces : Postes, partages, conservation, suppression
Statut : Existant

7. Flux d'information

- Un client adresse une demande de support. Le service support crée un ticket dans A04 et peut recevoir une pièce jointe.
- Les collaborateurs accèdent au ticket selon leur rôle. Des exports A10 peuvent être créés.
- Une correction applicative est préparée dans A05 puis déployée sur l'application locale.
- A06 sauvegarde les données. A07 reçoit une partie des événements techniques.
- Le pilote A08 reçoit uniquement des tickets artificiels. Le futur transfert de données réelles demeure suspendu à la décision fournisseur.

Les tickets réels du scénario peuvent contenir noms, courriels professionnels et descriptions techniques. La PSSI proposée interdit mots de passe, clés privées, données de santé et documents d'identité dans les tickets.

8. Contexte climatique et continuité

L'analyse du contexte retient les interruptions d'alimentation et la chaleur comme hypothèses pouvant affecter les équipements et la disponibilité. Elles doivent être examinées avec les dépendances électriques, réseau et d'hébergement. Aucune étude climatique locale ni probabilité d'événement n'est inventée.

Le point de contexte est documenté pour prendre en compte l'amendement 2024. Il ne transforme pas ce projet cyber en audit environnemental.

9. Hypothèses à confirmer

Hypothèse	Effet sur l'analyse
RTO local de huit heures et RPO de 24 heures	Si le métier exige moins, les mesures et certains impacts doivent être réévalués
Pas de données sensibles réglementaires dans les tickets	Si elles apparaissent, la criticité et les obligations doivent être revues
Aucun accès SupportCloud aux systèmes de production	Tout connecteur ou compte technique étendu impose une nouvelle évaluation
Usage fournisseur en pilote artificiel	Les risques fournisseur sont prospectifs, non une preuve d'exposition de clients réels
Sources internes simulées	Conclusions limitées à la cohérence du cas

Références

ISO/IEC 27001, amendement 2024, communiqué ISO/IAF.

Source éditable : Projet_1_SSI/02_methode_registre_risques.md

Projet 1 - Méthode et registre des risques

Cas pédagogique simulé - version 1.0 - 7 octobre 2026

1. Méthode retenue

Chaque risque décrit une menace, une faiblesse exploitable, les actifs concernés et une conséquence SSI. La méthode est inspirée de la gestion des risques SSI, avec une cotation locale définie pour l'exercice.

Le score est **vraisemblance V × impact I**. Les valeurs ordinales servent à prioriser. Elles ne représentent ni une probabilité annuelle chiffrée, ni une perte monétaire attendue.

L'horizon de comparaison est les douze mois suivant la situation de référence du 7 octobre 2026. Pour le SaaS, il correspond aux douze premiers mois d'un éventuel usage en production dans les conditions décrites. Cet horizon commun ne transforme pas les indices en fréquences mesurées.

Trois niveaux sont conservés :

- **Inhérent** : scénario considéré sans les mesures existantes retenues dans l'analyse.
- **Actuel estimé** : mesures existantes prises en compte dans la limite des justificatifs.
- **Cible estimée** : résultat envisagé si les actions sont déployées et leur efficacité vérifiée.

Le risque résiduel doit être réévalué sur la base de mesures effectivement mises en œuvre et de preuves de leur efficacité. Cette réévaluation après traitement n'est pas encore réalisée. Elle n'est pas remplacée par le risque cible.

2. Échelles

Vraisemblance

V	Interprétation locale
1	Peu plausible : chemin d'attaque restreint et plusieurs barrières vérifiées seraient nécessaires
2	Possible : exposition limitée et contrôles crédibles, avec limites connues
3	Plausible : chemin identifiable et mesures partielles
4	Probable dans le scénario : faiblesse directement exploitable ou exposition importante
5	Très probable : répétition ou exploitation active documentée dans le cas

Ces appréciations exigent un raisonnement sur le scénario. Une pièce manquante ne suffit pas à attribuer V = 4 ou 5.

Impact

I	Confidentialité	Intégrité	Disponibilité du service concerné
1	Information publique ou divulgation négligeable	Correction immédiate sans effet métier	Interruption brève sans effet significatif
2	Information interne limitée	Erreur locale réversible	Perturbation limitée, contournement disponible
3	Information confidentielle limitée	Reprise manuelle de dossiers	Interruption significative, activité dégradée
4	Ensemble important de données clients ou de code	Altération étendue avec reprise difficile	Arrêt du support sans contournement immédiat, ou interruption dépassant l'objectif métier
5	Identités privilégiées ou exposition susceptible de compromettre largement les systèmes	Perte de maîtrise majeure des systèmes ou dossiers	Arrêt prolongé de la fonction critique, reprise incertaine

L'impact retenu est le maximum des dimensions **du scénario**, pas automatiquement le maximum de la fiche actif. Une mesure de sauvegarde peut réduire un impact de disponibilité si la reprise est démontrée. Elle ne réduit pas, à elle seule, l'impact d'une fuite.

Priorités

Score	Niveau	Décision attendue
1 à 4	Faible	Acceptation possible par le propriétaire, avec justification et revue
5 à 9	Modéré	Traitement proportionné ou acceptation documentée, approuvée par le propriétaire et le RSSI
10 à 15	Élevé	Plan obligatoire ; exception temporaire soumise à la DG
16 à 25	Critique	Mesure de réduction immédiate ou suspension du nouvel usage ; arbitrage DG

Un faible score ne dispense pas d'une obligation applicable. Une preuve insuffisante impose une demande complémentaire avant d'affirmer l'efficacité du contrôle.

3. Registre synthétique

Notation : chaque triplet indique **V / I / score**. Les douze risques ne sont pas additionnés, car leurs événements et conséquences peuvent se recouper.

Lecture du tableau par entrée : tous les champs sont conservés.

ID : R01

Scénario et actifs : Vol ou partage d'un compte privilégié permettant une prise de contrôle d'A01/A04
Propriétaire du risque : RI
Inhérent : 4/5/20
Actuel estimé : 4/5/20
Niveau actuel : Critique
Cible conditionnelle : 1/5/5
Traitement : Réduire, M01

ID : R02

Scénario et actifs : Phishing d'un collaborateur puis accès aux échanges clients A02
Propriétaire du risque : RS
Inhérent : 4/4/16
Actuel estimé : 3/4/12
Niveau actuel : Élevé
Cible conditionnelle : 2/4/8
Traitement : Réduire, M02

ID : R03

Scénario et actifs : Chiffrement ou perte de l'application A04 avec restauration A06 inutilisable
Propriétaire du risque : RI
Inhérent : 4/5/20
Actuel estimé : 4/5/20
Niveau actuel : Critique
Cible conditionnelle : 2/4/8
Traitement : Réduire, M03

ID : R04

Scénario et actifs : Incident persistant faute de collecte et de revue suffisantes sur A07
Propriétaire du risque : RI
Inhérent : 4/4/16
Actuel estimé : 3/4/12
Niveau actuel : Élevé
Cible conditionnelle : 2/4/8
Traitement : Réduire, M04

ID : R05

Scénario et actifs : Exploitation d'une faiblesse applicative non traitée sur A04
Propriétaire du risque : RD
Inhérent : 4/4/16
Actuel estimé : 3/4/12
Niveau actuel : Élevé
Cible conditionnelle : 2/4/8
Traitement : Réduire, M05

ID : R06

Scénario et actifs : Secret applicatif commité puis réutilisé pour accéder aux services A05/A04
Propriétaire du risque : RD
Inhérent : 4/4/16
Actuel estimé : 4/4/16
Niveau actuel : Critique
Cible conditionnelle : 1/4/4
Traitement : Réduire, M06

ID : R07

Scénario et actifs : Maintien d'un accès après départ et consultation des tickets A01/A04
Propriétaire du risque : RI
Inhérent : 3/4/12
Actuel estimé : 3/4/12
Niveau actuel : Élevé
Cible conditionnelle : 1/4/4
Traitement : Réduire, M07

ID : R08

Scénario et actifs : Futur accès inter-clients non autorisé dans SupportCloud A08
Propriétaire du risque : RS
Inhérent : 4/4/16
Actuel estimé : 4/4/16
Niveau actuel : Critique, prospectif
Cible conditionnelle : 2/4/8
Traitement : Éviter l'exposition en production puis réduire, M08

ID : R09

Scénario et actifs : Export A10 conservé sans justification et partagé trop largement
Propriétaire du risque : RS
Inhérent : 3/3/9
Actuel estimé : 3/3/9
Niveau actuel : Modéré
Cible conditionnelle : 2/3/6
Traitement : Réduire, M09

ID : R10

Scénario et actifs : Absence d'un administrateur et documentation A09 insuffisante pour reprendre le service
Propriétaire du risque : RI
Inhérent : 3/3/9
Actuel estimé : 3/3/9
Niveau actuel : Modéré
Cible conditionnelle : 2/3/6
Traitement : Réduire, M10

ID : R11

Scénario et actifs : Perte d'un portable A03 non chiffré exposant des informations clients
Propriétaire du risque : RI
Inhérent : 4/4/16
Actuel estimé : 4/4/16
Niveau actuel : Critique
Cible conditionnelle : 1/4/4
Traitement : Réduire, M11

ID : R12

Scénario et actifs : Modification non validée d'A04 altérant les tickets sans retour arrière préparé
Propriétaire du risque : RD
Inhérent : 3/4/12
Actuel estimé : 3/4/12
Niveau actuel : Élevé
Cible conditionnelle : 2/4/8
Traitement : Réduire, M12

4. Fondement des cotations actuelles

Risque	Éléments du cas et mesures existantes	Justification de l'appréciation et limite
R01	E02 : un compte partagé et deux comptes privilégiés sans MFA sur trois	V4 reflète un chemin d'accès direct ; I5 la portée d'un compte privilégié. Le MFA du troisième compte ne couvre pas les deux autres
R02	E10 : sensibilisation ponctuelle ; protection de base de messagerie déclarée	V3 tient compte d'une barrière partielle. Aucun exercice récent ne démontre une efficacité durable
R03	E02 : accès privilégiés insuffisamment protégés ; E04 : sept sauvegardes annoncées réussies, aucune preuve de restauration	V4 est une hypothèse conservatrice du scénario composé de compromission puis reprise insuffisante. L'exposition des accès étaye la possibilité d'une compromission ; l'absence de rapport ne prouve pas un échec de restauration. Confiance limitée sur V et la reprise
R04	E03 : un événement visible, deux sources sur six déclarées couvertes	V3 concerne la persistance non détectée. Le dispositif pilote apporte un signal limité, insuffisant pour généraliser
R05	E09 : faiblesse élevée ouverte sur le serveur local ; accès réseau déjà limité	V3 reconnaît la restriction d'accès, mais le correctif reste nécessaire
R06	E05 : marqueur de secret de démonstration présent dans l'historique fictif	La cotation suppose, dans le scénario uniquement, qu'un secret utilisable aurait été exposé. Aucune clé réelle n'est fournie
R07	E07 : compte fictif actif sept jours après départ	Chemin plausible et accès client résiduel. L'échantillon ne mesure pas tous les départs
R08	V06 du projet 2 : défaut d'autorisation inter-clients ouvert dans le rapport simulé	Le risque est conditionné à l'usage réel futur. Il reprend S08, sans additionner les huit risques fournisseur
R09	E10 : conservation et règles de partage non formalisées	V3 est un jugement de scénario lié à la présence d'exports, pas une conclusion tirée uniquement d'un document absent
R10	E10 : procédures détenues par un seul administrateur	La dépendance humaine justifie l'étude de continuité. Aucun arrêt réel n'est inventé
R11	E06 : un portable non chiffré sur trois examinés	V4 est une hypothèse prudente pour la perte de ce poste et son exposition. Le taux observé sur trois postes n'est pas extrapolé aux 40
R12	E08 : déploiement explicitement marqué sans approbation et sans retour arrière	V3/I4 portent sur une modification affectant la base de tickets. Pas de test réel de corruption

La confiance est suffisante **pour suivre le raisonnement du cas simulé** lorsqu'un artefact précis soutient le constat. Elle est limitée pour l'efficacité dans la durée, les populations non échantillonnées et tous les risques cible.

5. Conditions des cotations cible

- R01 : MFA applicable aux accès privilégiés, suppression du partage, récupération sécurisée et vérification des exceptions.
- R02 : protections d'accès et de messagerie complétées, exercice de sensibilisation et contrôle des accès clients.
- R03 : sauvegarde isolée et protégée, restauration répétable, intégrité et objectifs métier vérifiés. I5 devient I4 uniquement dans cette hypothèse.
- R04 : sources prioritaires couvertes, alerte et revue démontrées, conservation et accès aux journaux examinés.
- R05 : correction validée et suivi des vulnérabilités opérationnel.
- R06 : secret invalidé, rotation démontrée, historique traité et accès au dépôt revus. Le scanner automatique reste une option, pas une condition du présent travail documentaire.
- R07 : sortie testée jusqu'au retrait des sessions, jetons et comptes.
- R08 : fermeture et retest de S08, puis levée de tous les autres blocages du projet 2.
- R09 : minimisation, durée justifiée et partage limité réellement appliqués.
- R10 : suppléance et procédure exercées.
- R11 : chiffrement du poste testé et récupération maîtrisée.
- R12 : approbation, séparation des droits, test et retour arrière vérifiés.

Pour R03, I4 reste une estimation conservatrice d'un arrêt complet du support, même si la reprise devient maîtrisée. Atteindre un RTO ne rend pas l'interruption sans conséquence. La réduction I5 vers I4 doit être justifiée par une reprise réelle et une validation métier ; elle n'est pas automatique à partir d'un job réussi.

Sensibilité des hypothèses prudentes

R03 et R11 nécessitent une attention particulière : la fréquence d'incident destructif, de déplacement ou de perte de portable n'est pas mesurée. Leur V4 est une hypothèse de priorisation, pas un constat statistique.

Variante à discuter	Score résultant	Effet sur la priorité
R03 : V3 au lieu de V4, I5 conservé	15, élevé	Le traitement et la preuve de reprise restent nécessaires
R11 : V3 au lieu de V4, I4 conservé	12, élevé	Le chiffrement du poste exposé reste nécessaire

Si ces deux variantes étaient retenues ensemble, la répartition serait trois critiques, sept élevés et deux modérés, au lieu de cinq critiques, cinq élevés et deux modérés. La version de référence conserve V4 ; cette sensibilité explique pourquoi les nombres ne doivent pas être présentés comme une mesure objective du marché, d'incidents ou de conformité.

6. Arbitrage et suivi

Répartition actuelle : cinq risques critiques, cinq élevés et deux modérés. Parmi les cinq critiques, R08 concerne le projet SaaS avant production. Les onze expositions existantes comprennent quatre critiques, cinq élevées et deux modérées.

Répartition cible estimée : trois faibles et neuf modérés, seulement si les conditions ci-dessus sont satisfaites. Aucun risque n'est clôturé à ce stade.

Le registre sera revu après preuve de traitement, changement d'architecture, incident, ajout de données sensibles ou changement fournisseur. Une acceptation précisera le risque, le niveau actuel, les mesures compensatoires, le propriétaire, l'autorité, une échéance et une condition de réexamen.

Exemple d'acceptation correctement bornée

R09, score actuel 9 : maintien temporaire d'un export limité sur un espace à accès restreint, durée de trente jours, sous responsabilité RS, avec revue RSSI. **Décision proposée, non signée.** Aucune acceptation automatique de R01 ou R08 n'en découle.

Référence

ISO/IEC 27005:2022. Les échelles, niveaux, exemples et décisions sont propres au cas.

Source éditable : Projet_1_SSI/03_traitement_controles_SoA.md

Projet 1 - Traitement, mesures et extrait de SoA

Cas pédagogique simulé - version 1.0 - 7 octobre 2026

1. Plan de traitement proposé

J correspond au 7 octobre 2026. Les délais sont des jours calendaires et des objectifs locaux. Toutes les actions sont **proposées, non réalisées**. Le coût n'est pas inventé : les pilotes doivent l'estimer avant arbitrage.

Lecture du tableau par entrée : tous les champs sont conservés.

Action : M01

Risque : R01
Mesure proposée : Retirer l'accès partagé, limiter les droits, imposer le MFA privilégié et contrôler la récupération
Pilote : RI
Délai cible : J+2, 9 octobre
Critère de clôture : Export de tous les comptes privilégiés, exceptions approuvées, essais positifs/négatifs et retrait des sessions

Action : M02

Risque : R02
Mesure proposée : Compléter protection des accès et de la messagerie, sensibilisation adaptée au phishing
Pilote : RI et RS
Délai cible : J+30, 6 novembre
Critère de clôture : Configurations et exercice documentés, accès revus, canal d'alerte connu

Action : M03

Risque : R03
Mesure proposée : Protéger les sauvegardes, séparer les accès et réaliser une restauration de contrôle
Pilote : RI
Délai cible : Mesure conservatoire J+2 ; preuve complète J+15, 22 octobre
Critère de clôture : Test isolé, intégrité, RTO/RPO validés et procédure répétable

Action : M04

Risque : R04
Mesure proposée : Étendre les sources prioritaires, définir alerte, revue, conservation et protection des journaux
Pilote : RI
Délai cible : J+30, 6 novembre
Critère de clôture : Inventaire des sources, réception et alerte testées, revue et contrôle des accès

Action : M05

Risque : R05
Mesure proposée : Réduire l'exposition de la fonction vulnérable, corriger et faire valider le correctif
Pilote : RD
Délai cible : Restriction J+2 ; correction J+10, 17 octobre
Critère de clôture : Preuve de correction et retest autorisé, sans vulnérabilité ouverte équivalente

Action : M06

Risque : R06
Mesure proposée : Invalider le secret exposé dans le scénario, effectuer la rotation et contrôler le dépôt et son historique
Pilote : RD
Délai cible : J+1, 8 octobre
Critère de clôture : Ancien secret inutilisable, nouveau secret stocké hors dépôt, revue documentée des chemins concernés

Action : M07

Risque : R07
Mesure proposée : Désactiver l'accès de départ et formaliser le retrait de comptes, sessions et jetons
Pilote : RI et RH
Délai cible : Cas ouvert J+1 ; processus J+15
Critère de clôture : Preuve de retrait de l'accès et fiche de sortie complète

Action : M08

Risque : R08
Mesure proposée : Maintenir le SaaS hors production et exiger la clôture du défaut inter-clients et des blocages fournisseur
Pilote : RS
Délai cible : Avant toute donnée réelle
Critère de clôture : Décision fondée sur preuves et critères du projet 2, sans acceptation par simple courriel commercial

Action : M09

Risque : R09
Mesure proposée : Limiter exports et accès, fixer une durée justifiée et une suppression contrôlée
Pilote : RS
Délai cible : J+30, 6 novembre
Critère de clôture : Inventaire des exports, habilitations et exemple de suppression

Action : M10

Risque : R10
Mesure proposée : Désigner un suppléant et exercer une procédure de reprise documentaire
Pilote : RI
Délai cible : J+60, 6 décembre
Critère de clôture : Exercice effectué par le suppléant et limites relevées

Action : M11

Risque : R11
Mesure proposée : Chiffrer le poste concerné, conserver la récupération en lieu contrôlé et examiner les autres postes
Pilote : RI
Délai cible : Poste ouvert J+2 ; inventaire J+15
Critère de clôture : État du volume et récupération contrôlée, couverture documentée

Action : M12

Risque : R12
Mesure proposée : Mettre en place approbation, vérification et retour arrière pour les changements sensibles
Pilote : RD
Délai cible : J+30, 6 novembre
Critère de clôture : Dossier d'un changement complet, approbation indépendante et vérification du retour arrière

La suppression d'un secret dans la dernière version d'un fichier ne clôture pas M06 si le secret reste utilisable ou présent dans l'historique. La réussite d'un job ne clôture pas M03. La simple activation d'un agent ne clôture pas M04.

2. Sélection des mesures

Les mesures répondent aux risques identifiés, aux critères métier et aux besoins de gouvernance. ISO/IEC 27002 sert de guide. D'autres mesures peuvent être nécessaires dans un SMSI complet.

Groupe	Risques principaux	Repères ISO/IEC 27001 annexe A / ISO/IEC 27002	Application concrète retenue
Gouvernance	Tous	5.1, 5.2, 5.9	PSSI, rôles, actifs et décisions
Identités et secrets	R01, R06, R07	5.17, 5.18, 8.2, 8.4, 8.5	Comptes nominatifs, MFA, droits, secret hors dépôt et retrait des accès
Fournisseur et cloud	R08	5.19, 5.20, 5.22, 5.23	Diligence, contrat, décision, suivi et sortie
Sensibilisation et incident	R02, R04, R10	6.3, 5.24	Consignes, signalement, responsabilités et exercice
Robustesse technique	R03, R05, R11, R12	8.8, 8.13, 8.24, 8.32	Correctifs, restauration, chiffrement et changements
Visibilité	R04	8.15, 8.16	Collecte, protection, revue et réponse aux signaux

3. Extrait de déclaration d'applicabilité

SoA signifie Statement of Applicability, ou déclaration d'applicabilité.

L'extrait comporte vingt repères sélectionnés. Les thèmes sont reformulés pour le cas et ne reproduisent pas les libellés normatifs. « Retenue » signifie sélectionnée pour le traitement et la gouvernance du cas. « Partielle » décrit la mise en œuvre déclarée dans les documents simulés, pas une conformité à la norme.

Le travail complet doit comparer les mesures nécessaires avec l'ensemble de l'annexe A pour vérifier qu'aucune mesure nécessaire n'a été oubliée. La SoA doit documenter les mesures retenues, leur justification, leur état de mise en œuvre et les justifications d'exclusion des mesures de référence ; des mesures supplémentaires peuvent être nécessaires. **Aucune exclusion de l'annexe A n'est prononcée dans cet extrait.**

Lecture du tableau par entrée : tous les champs sont conservés.

Repère : 5.1

Thème adapté au cas : Politique SSI
Retenue et justification : Oui : règles et arbitrages communs
État actuel du cas : Non démontré, document approuvé absent du dossier
Pièce ou action : E10, PSSI proposée
Responsable : DG

Repère : 5.2

Thème adapté au cas : Attribution des responsabilités
Retenue et justification : Oui : propriétaires et validation
État actuel du cas : Partielle, rôles informels
Pièce ou action : E10, contexte et revue
Responsable : DG

Repère : 5.9

Thème adapté au cas : Inventaire et propriétaires des actifs
Retenue et justification : Oui : dépendances et criticité
État actuel du cas : Partiel
Pièce ou action : E01, inventaire proposé
Responsable : RI

Repère : 5.17

Thème adapté au cas : Protection des informations d'authentification
Retenue et justification : Oui : R01/R06
État actuel du cas : Insuffisante dans le scénario de secret
Pièce ou action : E05, M06
Responsable : RD

Repère : 5.18

Thème adapté au cas : Cycle de vie des habilitations
Retenue et justification : Oui : R01/R07
État actuel du cas : Partiel, retrait de départ défaillant
Pièce ou action : E02/E07, M01/M07
Responsable : RI

Repère : 5.19

Thème adapté au cas : Risques liés aux fournisseurs
Retenue et justification : Oui : R08
État actuel du cas : Diligence préparée, décision encore ouverte
Pièce ou action : Projet 2, M08
Responsable : RS

Repère : 5.20

Thème adapté au cas : Exigences de sécurité contractuelles
Retenue et justification : Oui : incident, données et sortie
État actuel du cas : Non démontré pour le contrat final
Pièce ou action : V08, projet 2
Responsable : RS et RJ

Repère : 5.22

Thème adapté au cas : Revue de la sécurité fournisseur
Retenue et justification : Oui : changements et engagements
État actuel du cas : À organiser
Pièce ou action : Projet 2, calendrier de suivi
Responsable : RS

Repère : 5.23

Thème adapté au cas : Usage et sortie du cloud
Retenue et justification : Oui : A08 et dépendance
État actuel du cas : Pilote seulement
Pièce ou action : V01/V08, projet 2
Responsable : RS

Repère : 5.24

Thème adapté au cas : Préparation de réponse aux incidents
Retenue et justification : Oui : escalade et coordination
État actuel du cas : Non démontrée
Pièce ou action : E10, procédure proposée
Responsable : RSSI

Repère : 6.3

Thème adapté au cas : Sensibilisation et apprentissage SSI
Retenue et justification : Oui : R02
État actuel du cas : Ponctuelle
Pièce ou action : E10, M02
Responsable : RS

Repère : 8.2

Thème adapté au cas : Accès privilégiés
Retenue et justification : Oui : R01
État actuel du cas : Partiel, compte partagé
Pièce ou action : E02, M01
Responsable : RI

Repère : 8.4

Thème adapté au cas : Accès au code
Retenue et justification : Oui : R06/R12
État actuel du cas : Dépôt privé déclaré, revue des droits non démontrée
Pièce ou action : E05, M06/M12
Responsable : RD

Repère : 8.5

Thème adapté au cas : Authentification sûre
Retenue et justification : Oui : R01/R02
État actuel du cas : MFA incomplet
Pièce ou action : E02, M01
Responsable : RI

Repère : 8.8

Thème adapté au cas : Gestion des faiblesses techniques
Retenue et justification : Oui : R05
État actuel du cas : Faiblesse ouverte
Pièce ou action : E09, M05
Responsable : RD

Repère : 8.13

Thème adapté au cas : Sauvegardes et restaurabilité
Retenue et justification : Oui : R03
État actuel du cas : Jobs présents, restauration non démontrée
Pièce ou action : E04, M03
Responsable : RI

Repère : 8.15

Thème adapté au cas : Production et protection des journaux
Retenue et justification : Oui : R04
État actuel du cas : Partielle
Pièce ou action : E03, M04
Responsable : RI

Repère : 8.16

Thème adapté au cas : Surveillance et examen des signaux
Retenue et justification : Oui : R04
État actuel du cas : Signal pilote, examen régulier non démontré
Pièce ou action : E03, M04
Responsable : RI

Repère : 8.24

Thème adapté au cas : Chiffrement adapté aux données
Retenue et justification : Oui : R11 et confidentialité
État actuel du cas : Partiel sur l'échantillon
Pièce ou action : E06, M11
Responsable : RI

Repère : 8.32

Thème adapté au cas : Maîtrise des changements
Retenue et justification : Oui : R12
État actuel du cas : Écart explicite dans le cas
Pièce ou action : E08, M12
Responsable : RD

4. Exemple de décision de traitement

R01 - décision proposée

La direction fictive reçoit un risque actuel estimé à 20. Le traitement M01 est prioritaire. Tant que le MFA n'est pas imposé et vérifié, un score cible de 5 ne peut pas être repris comme score actuel.

Si un accès de secours est maintenu, le dossier doit justifier sa nécessité, son stockage, les accès autorisés, la surveillance, les conditions d'utilisation et la revue. « MFA sur tous les comptes sauf le compte de secours » ne constitue pas une exception suffisamment examinée.

5. Validation et preuve

Le pilote fournit le justificatif. Le RSSI vérifie sa pertinence, la population, la date, le périmètre et le résultat. Le propriétaire réévalue le risque. L'autorité prévue approuve le traitement ou l'acceptation.

Statuts possibles : proposée, planifiée, en cours, preuve reçue, vérifiée, acceptation approuvée, close. Une action ne passe pas directement de proposée à close.

Références

ISO/IEC 27001, ISO/IEC 27002. Les mesures et critères de clôture sont adaptés au cas pédagogique.

Source éditable : Projet_1_SSI/04_preuves_et_constats.md

Projet 1 - Justificatifs et constats documentaires

Cas pédagogique simulé - version 1.0 - 7 octobre 2026

1. Règles d'examen

Tous les éléments E01 à E10 ci-dessous sont **SIMULÉS**. Leurs dates appartiennent au scénario, pas à une exécution réelle par Anas.

Chaque conclusion distingue :

- **conception** : le contrôle prévu répond-il au risque et au besoin ?
- **mise en œuvre documentée** : un paramétrage ou une opération est-il décrit ?
- **fonctionnement dans la durée** : une période et des preuves suffisantes existent-elles ?

Les catégories de conclusion sont : satisfait pour la pièce et le périmètre examinés, partiellement satisfait, écart au critère de l'atelier, ou non démontré. Elles ne signifient pas « certifié ISO ».

2. Dossier d'entreprise simulé

E01 - Inventaire initial, 30 septembre 2026

Provenance fictive : fichier du service infrastructure, version initiale. Six lignes décrivent annuaire, serveur de tickets, dépôt Git, sauvegardes, SIEM et documentation. Deux lignes n'ont pas de propriétaire ; les portables, exports, messagerie et SaaS candidat ne figurent pas dans cette version.

Conclusion : inventaire partiel par comparaison avec le périmètre déclaré. L'inventaire proposé de dix actifs est une correction documentaire préparée, encore à valider.

E02 - État des accès privilégiés, 6 octobre 2026

Provenance fictive : export de configuration de l'annuaire. Population du cas : trois comptes privilégiés pour deux administrateurs.

Lecture du tableau par entrée : tous les champs sont conservés.

Compte fictif : ADM01

Type : Nominatif
Actif : Oui
MFA imposé : Oui
Responsable identifié : Administrateur 1

Compte fictif : ADM02

Type : Nominatif
Actif : Oui
MFA imposé : Non
Responsable identifié : Administrateur 2

Compte fictif : ADMIN-PARTAGE

Type : Partagé

Actif : Oui

MFA imposé : Non

Responsable identifié : Deux utilisateurs, responsabilité ambiguë

L'export permet de conclure que la configuration simulée ne satisfait pas l'objectif du cas. Il ne démontre pas, pour ADM01, un fonctionnement effectif ou une récupération sûre.

E03 - Journalisation pilote, 5 octobre 2026

Provenance fictive : fiche de couverture et relevé du tableau de bord Wazuh. Deux sources actives sur six sources déclarées prioritaires. Un échec de connexion est visible pour LAB-WIN-01 à 10 h 02. Une alerte associée est affichée à 10 h 03.

Pas de relevé de conservation, de protection des journaux, d'accès au tableau de bord ou de revue quotidienne.

Conclusion : présence d'un signal dans le relevé simulé. Couverture incomplète et efficacité durable non démontrée. Le temps d'une minute ne constitue pas une mesure de performance de production.

E04 - Sauvegardes, semaine du 28 septembre au 4 octobre 2026

Provenance fictive : relevé de sept jobs quotidiens du serveur de tickets, chacun marqué réussi. Dernier job annoncé : 4 octobre à 23 h.

Le dossier de restauration contient un état « aucun compte rendu fourni ». Les droits du compte de sauvegarde et l'isolement du stockage ne sont pas documentés.

Conclusion : exécution déclarée de sauvegardes pendant la période. Restaurabilité et objectifs de reprise non démontrés. Ne pas conclure à l'absence de sauvegarde.

E05 - Revue du dépôt, 6 octobre 2026

Provenance fictive : fiche de revue d'un dépôt privé. La fiche signale un marqueur « SECRET-DEMO-NON-UTILISABLE » dans un fichier de configuration et dans une ancienne version.

L'énoncé stipule qu'un secret exploitable aurait été actif dans ce scénario. Le marqueur représente cette exposition ; **ce n'est pas une vraie clé**. Aucune rotation ou invalidation n'est consignée.

Conclusion : écart du scénario de protection des secrets. La confidentialité d'un dépôt ne protège pas un secret contre tous ses lecteurs ou contre une future divulgation.

E06 - Chiffrement de postes, 6 octobre 2026

Provenance fictive : trois fiches de configuration prises dans un parc de 40 postes.

Poste	Chiffrement déclaré	Récupération documentée
PC01	Activé	Non fournie
PC02	Activé	Non fournie
PC03	Désactivé	Sans objet à ce stade

Conclusion : écart explicite sur PC03. Le statut des 37 autres postes et la récupérabilité de PC01/PC02 ne sont pas démontrés.

E07 - Départ et accès, 7 octobre 2026

Provenance fictive : départ RH effectif le 30 septembre ; compte utilisateur TST-DEPART encore actif le 7 octobre et accès au serveur de tickets conservé.

Conclusion : écart de retrait d'accès dans le cas. La revue ne prétend pas avoir examiné tous les départs historiques.

E08 - Changement applicatif, 1er octobre 2026

Provenance fictive : fiche de déploiement sur le serveur local de tickets. Champs renseignés : approbation avant production « non », vérification après changement « partielle », retour arrière documenté « non ».

Conclusion : écart explicite du cas. Un ticket sans signature aurait seulement justifié une demande complémentaire ; ici l'énoncé indique directement l'absence d'approbation.

E09 - Vulnérabilité locale, relevé du 12 septembre 2026

Provenance fictive : fiche de vulnérabilité élevée sur la fonction de recherche de tickets, accès réservé aux utilisateurs authentifiés. Correctif non installé et retest non réalisé au 7 octobre.

Aucune cible réelle ni charge d'exploitation n'est fournie. L'accès restreint est une mesure existante, mais ne supprime pas le risque d'exploitation par un compte compromis.

E10 - Entretien de contexte, 7 octobre 2026

Provenance fictive : notes du responsable infrastructure et du responsable support.

- Rôles SSI connus oralement ; PSSI approuvée non fournie.
- Méthode préalable, registre de risques et suivi de traitement non fournis.
- Sensibilisation ponctuelle réalisée dans le scénario ; aucune mesure récente de son efficacité.
- Filtrage de base de la messagerie déclaré, non testé.
- Exports de tickets présents ; règles de durée et de partage non formalisées.
- Procédures d'exploitation principalement détenues par un administrateur.
- Procédure de réponse aux incidents et compte rendu d'exercice non fournis.

Conclusion : déclarations utiles au cadrage, avec assurance limitée. Les absences documentaires sont conservées comme informations non démontrées.

3. Matrice de constats

Lecture du tableau par entrée : tous les champs sont conservés.

Constat : C01

Critère de l'atelier : Accès privilégiés nominatifs, nécessaires et protégés
Justificatif et examen : E02, lecture des trois comptes
Conclusion documentée : Écart de conception et configuration sur deux comptes ; fonctionnement d'ADM01 non testé
Risque et action : R01, M01, T01

Constat : C02

Critère de l'atelier : Sources prioritaires surveillées et journaux exploitables
Justificatif et examen : E03, couverture deux sur six et un relevé
Conclusion documentée : Partiel pour la couverture ; conservation/protection/revue non démontrées
Risque et action : R04, M04, T02

Constat : C03

Critère de l'atelier : Sauvegardes restaurables selon les besoins métier
Justificatif et examen : E04, sept jobs, aucun rapport de restauration
Conclusion documentée : Existence déclarée des jobs ; restaurabilité non démontrée
Risque et action : R03, M03, T03

Constat : C04

Critère de l'atelier : Secret utilisable absent du dépôt et invalidé après exposition
Justificatif et examen : E05, fiche de revue et historique fictifs
Conclusion documentée : Écart explicite dans le scénario ; aucune clé réelle exposée
Risque et action : R06, M06, T04

Constat : C05

Critère de l'atelier : Fin des accès au départ effectif
Justificatif et examen : E07, comparaison date de départ et accès
Conclusion documentée : Écart constaté pour le compte examiné
Risque et action : R07, M07

Constat : C06

Critère de l'atelier : Postes transportant des données clients protégés
Justificatif et examen : E06, trois fiches
Conclusion documentée : Écart PC03 ; conclusion limitée à l'échantillon
Risque et action : R11, M11

Constat : C07

Critère de l'atelier : Vulnérabilité identifiée suivie et traitée
Justificatif et examen : E09, état de la fiche
Conclusion documentée : Faiblesse ouverte ; aucune validation de correction
Risque et action : R05, M05

Constat : C08

Critère de l'atelier : Changement sensible approuvé et retour arrière préparé
Justificatif et examen : E08, fiche explicitement renseignée
Conclusion documentée : Écart sur le changement examiné
Risque et action : R12, M12

C03 est une illustration importante : **une preuve de restauration absente ne démontre pas que la sauvegarde n'existe pas ou que la restauration échouera.** Elle empêche d'affirmer la restaurabilité.

4. Examen limité des exigences du SMSI

Il s'agit d'une gap analysis pédagogique ciblée, pas d'une évaluation exhaustive des clauses.

Sujet et repère	Situation du cas	Document proposé	Limite restante
Contexte, parties intéressées et périmètre - 4	Informations dispersées, inventaire partiel	Document 01	Validation du métier et interfaces manquantes

Sujet et repère	Situation du cas	Document proposé	Limite restante
Politique et responsabilités - 5	Rôles informels, PSSI approuvée non fournie	PSSI et gouvernance	Approbation et diffusion non réalisées
Appréciation et traitement - 6.1.2/6.1.3	Méthode initiale non fournie	Registre, plan et extrait de SoA	Texte normatif complet à relire ; acceptations non signées
Objectifs SSI - 6.2	Besoins de reprise proposés	Indicateurs de la synthèse	Besoins et ressources à valider
Compétences et documents - 7	Sensibilisation ponctuelle, documentation partielle	Procédures et guide	Historique et gestion documentaire à organiser
Exécution du traitement - 8	Actions encore proposées	Plan M01 à M12	Preuves d'exécution absentes
Évaluation - 9	Pas de revue exhaustive ni d'audit interne effectué	Matrice et revue proposée	Cette étude ne remplace pas un audit interne indépendant
Amélioration - 10	Pas de suivi formalisé fourni	Suivi et critères de clôture	Actions correctives et efficacité à vérifier

5. Conservation des nouvelles preuves

Pour une preuve réelle, enregistrer : identifiant, date et fuseau, système, propriétaire, origine, périmètre, opérateur, méthode, résultat, limites et lien vers la pièce.

Les captures doivent masquer identifiants sensibles, secrets, données clients et informations privées de tiers. Une pièce masquée doit conserver les informations nécessaires au raisonnement.

Les nouvelles pièces réelles seront nommées T01-P01, T02-P01, etc. Elles ne remplaceront jamais silencieusement les justificatifs E simulés.

Références

ISO/IEC 27001, ISO/IEC 27002. Les critères et conclusions sont ceux de l'atelier.

Source éditable : Projet_1_SSI/05_PSSI_procedures.md

Projet 1 - PSSI et procédures proposées

Cas pédagogique simulé - version 1.0 - 7 octobre 2026 Statut : propositions pour la PME fictive, non approuvées et non déployées.

PSSI proposée

1. Objet et responsabilité

La politique protège les informations et services du périmètre défini dans le document 01. La DG porte la décision et les ressources. Le RSSI coordonne la politique. Chaque responsable métier porte les risques et les informations de son domaine.

La politique est revue au moins annuellement, après un incident important, un changement de périmètre ou un changement fournisseur significatif. Une revue laisse une décision, une date, une version et un responsable.

2. Classification et usage des données

Trois niveaux sont retenus pour ce cas : public, interne et confidentiel. Les informations clients, le code non public, les journaux sensibles et les sauvegardes sont au minimum confidentiels.

Les tickets contiennent uniquement les données nécessaires au support. Les mots de passe, clés privées, documents d'identité et données de santé ne doivent pas y être déposés. Un exemple d'interdiction doit être montré lors de la sensibilisation.

Les exports ont un propriétaire, un usage, des destinataires limités et une durée justifiée. Pour l'exercice, un export de travail est supprimé après trente jours, sauf justification formalisée. Ce délai est un choix local à valider et non une règle légale générale.

3. Identités et habilitations

Les comptes humains sont nominatifs. Les droits suivent le besoin et le moindre privilège. Les fonctions d'administration sont séparées des usages ordinaires. Les comptes techniques ont un propriétaire et un usage explicites.

Le MFA est imposé pour les accès privilégiés et les accès distants retenus dans le périmètre. L'enregistrement d'un second facteur ne suffit pas : l'obligation et la récupération doivent être examinées.

Un accès de secours fait l'objet d'une justification, d'un stockage protégé, d'une traçabilité et d'une revue. Une exception ne doit pas être invisible dans l'inventaire.

Les droits sensibles sont revus trimestriellement et après une mobilité. Au départ d'une personne, l'accès est retiré à la date et à l'heure prévues. Une situation urgente impose une coordination RH, métier et infrastructure.

4. Secrets et code

Les secrets utilisables sont stockés dans un moyen adapté, hors du dépôt et des tickets. Leur accès est limité. La revue de code et la revue des droits du dépôt participent au contrôle.

En cas d'exposition, le secret est invalidé et remplacé. La dernière version et l'historique sont examinés. La suppression du texte ne remplace pas l'invalidation.

Les revues manuelles de l'exercice sont limitées au périmètre annoncé. Une recherche automatique exhaustive serait une extension technique distincte.

5. Postes et vulnérabilités

Les postes contenant des informations clients sont inventoriés, protégés, mis à jour et chiffrés selon le besoin. Les moyens de récupération du chiffrement sont conservés sous contrôle et testés sans exposer les clés.

Les vulnérabilités ont un propriétaire, une criticité et un délai de traitement. Dans le cas pédagogique, un défaut permettant l'accès non autorisé aux données clients bloque la mise en production du service concerné. Un délai générique ne remplace pas l'analyse de risque.

Les tests sont réalisés uniquement sur des environnements autorisés et des données artificielles.

6. Journaux et surveillance

Les sources prioritaires sont inventoriées. Pour chaque source, définir événements utiles, collecte, accès, protection, conservation, alertes et responsabilité de revue.

Le cas retient un objectif de disponibilité de 90 jours pour les journaux utiles du serveur de tickets et des accès privilégiés. La durée et les données collectées doivent être validées avec le besoin opérationnel et les obligations applicables.

Un événement visible prouve seulement le parcours testé. La couverture, les lacunes de collecte et les exceptions sont enregistrées.

7. Sauvegarde et continuité

L'application de tickets est sauvegardée quotidiennement. Le stockage et les comptes sont séparés des accès ordinaires. La restauration est exercée dans un environnement isolé.

Les objectifs proposés sont RTO huit heures et RPO 24 heures pour le service de tickets. Leur validation métier précède une acceptation du risque.

Le test vérifie les données restaurées, les dépendances et le service, pas seulement la présence de fichiers. Les échecs et limites sont conservés.

8. Fournisseurs

Un fournisseur critique est évalué avant production. Les preuves attendues portent sur le service, la formule et les engagements réellement achetés.

Le contrat précise responsabilités, protection des données, accès support, incidents, sous-traitance, journaux, réversibilité et fin de contrat. Un certificat hors périmètre ne clôture pas l'évaluation.

La validation de sécurité et l'examen des obligations relatives aux données personnelles sont enregistrés séparément. Le RSSI ne remplace pas la fonction juridique compétente.

9. Changements

Un changement sensible dispose d'un responsable, d'un risque examiné, d'une approbation, d'une vérification et d'un retour arrière. L'approbation indépendante est recherchée lorsque le même développeur prépare le changement.

Un changement d'urgence conserve sa justification et fait l'objet d'une revue ultérieure. « Urgent » ne signifie pas absence de dossier.

10. Exceptions et indicateurs

Chaque exception comporte son périmètre, sa justification, son risque, ses mesures compensatoires, son approbateur, sa date d'expiration et sa condition de réexamen.

Les indicateurs proposés dans la synthèse sont suivis après validation des populations et des sources. Aucun pourcentage global de conformité ISO n'est calculé.

Procédure A - Gestion des habilitations

Pilote : RI. Approbateur métier : propriétaire de l'information. Vérificateur : RSSI.

Étape	Action	Pièce attendue
1. Demande	Identifier personne ou service, rôle, systèmes, durée et droits demandés	Ticket d'accès et identité de test
2. Approbation	Le propriétaire vérifie nécessité et séparation des fonctions	Décision explicite avec date
3. Mise en place	Créer compte nominatif, limiter droits, imposer MFA si applicable	Relevé de droits et configuration
4. Vérification	Vérifier accès autorisé et refus d'un accès non nécessaire	Résultat positif et négatif
5. Revue	Examiner les droits sensibles et exceptions à l'échéance	Liste de population et décision

Étape	Action	Pièce attendue
6. Mobilité/départ	Retirer accès, sessions, jetons et comptes associés à l'heure prévue	Checklist de retrait et contrôle de refus
7. Archivage	Conserver décision et résultat avec accès limité	Dossier d'accès traçable

Exemple rempli dans le scénario E07 : départ du 30 septembre, contrôle du 7 octobre, accès encore actif. Action conservatoire M07 proposée. Aucun retrait réel n'est déclaré.

Point de contrôle : si l'application possède un compte local qui n'utilise pas l'annuaire, sa suppression doit être vérifiée séparément.

Procédure B - Sauvegarde et restauration

Pilote : RI. Validation fonctionnelle : RS.

- Définir les données et dépendances à sauvegarder avec le métier.
- Planifier le job, les droits, la protection et le stockage séparé.
- Examiner les résultats des jobs et traiter les erreurs.
- Sélectionner une sauvegarde pour un test isolé et enregistrer l'heure de départ.
- Restaurer vers un emplacement de test, jamais sur une donnée originale non sauvegardée.
- Vérifier trois enregistrements artificiels connus, leurs champs et l'usage de l'application ou du fichier de test.
- Enregistrer l'heure de fin, l'âge de la copie et les limites.
- Comparer le résultat aux objectifs applicables. Ouvrir une action si l'objectif n'est pas atteint ou n'est pas démontré.
- Faire valider le résultat par une autre personne, puis nettoyer les copies de test.

Une restauration de trois fichiers démontre ce périmètre seulement. Elle ne démontre pas la reprise complète du serveur, ni une sauvegarde résistante à toutes les attaques.

Procédure C - Signalement et coordination d'incident

Pilote : RSSI. Coordination métier : RS.

Phase	Action et limite
Signalement	Enregistrer date, source, système, observation et interlocuteur ; ne pas transmettre de secret dans le ticket
Qualification	Distinguer événement, alerte, faux positif et incident confirmé
Décision	Définir priorité, responsable et nécessité de confinement
Conservation	Préserver les pièces disponibles et leur provenance ; éviter les modifications non nécessaires
Coordination	Inclure les fournisseurs concernés et informer la DG selon la gravité
Reprise	Vérifier les dépendances et l'intégrité avant retour au service
Clôture	Confirmer critères de clôture, limites et actions d'amélioration

Un exercice sur papier peut vérifier les rôles et la circulation de l'information. Il ne démontre pas l'efficacité d'un confinement technique.

Gestion documentaire proposée

Documenter titre, version, auteur, relecteur, approbateur, date d'effet et historique. Pour cette version, l'approbation et la date d'effet sont **non réalisées**. Aucun paraphe ou accord de direction n'est simulé comme authentique.

Source éditable : Projet_1_SSI/06_tests_manuels.md

Protocoles des tests et observation historique

Version 1.1 - 07/10/2026. Quatre tests exécutés : trois réussites bornées ; T02 partiel.

La version 1.0 des protocoles est conservée dans la copie initiale. La mission actuelle autorise explicitement code et configurations utiles. Les critères sont conservés ; les étapes peuvent être automatisées si elles produisent une preuve réelle. Aucun système de stage, compte principal ou service fictif n'est ciblé.

T01 Accès MFA et sessions

R01/M01/C01. Service standard réel avec rôles, MFA imposé et révocation ; LAB-ADMIN et LAB-LECTEUR. Relever versions/règles ; accès lecteur permis et administration refusée ; administration permise ; nouvelle session mot de passe seul insuffisante ; mauvais OTP refusé et bon OTP accepté ; révocation suivie de refus ou réauthentification ; récupération et exceptions examinées. Pièces T01-P01 à P04. Résultats et limites (../Annexes_laboratoire/T01_RESULTATS.md). **RÉUSSI** dans le realm Keycloak dédié ; récupération examinée mais exercice complet non démontré.

T02 Événement collecte et SIEM

R04/M04/C02. Source Windows, compte artificiel, agent et Wazuh personnel accessibles. Identifier horloges et canaux ; produire un échec contrôlé ; relever localement l'événement puis retrouver même hôte/compte/ID/période dans Wazuh ; examiner alerte selon règle, sources, droits, conservation et protection. Conserver les résultats initiaux et documenter toute modification de collecte/règle avant retest. Pièces T02-P01 à P05. **PARTIEL** : source, réception et alerte prouvées ; limites de conservation (../Annexes_laboratoire/T02_RESULTATS.md). Le relevé d'un service actif ne remplace pas la réception.

T03 Sauvegarde restauration

R03/M03/C03. Au moins trois données artificielles connues, contenus/tailles/SHA-256 avant copie ; sauvegarde réelle identifiée et datée ; restauration séparée ; comparaison de chaque élément ; durée et âge de copie ; revue des droits. Vérifier tous les chemins avant modification/suppression, préserver l'échec éventuel puis corriger et retester. Pièces T03-P01 à P04. **RÉUSSI** : résultats ZIP de trois fichiers (../Annexes_laboratoire/T03_RESULTATS.md). RTO/RPO du service non démontrés.

T04 Secrets Git

R06/M06/C04. Nouveau dépôt local exclusivement dédié ; seul marqueur SECRET-DEMO-NON-UTILISABLE ; commit initial, retrait et nouveau commit ; constater absence courante et présence ancienne par Git réel ; revoir ACL locales ; écrire procédure de vraie exposition. Pièces T04-P01 à P04. **RÉUSSI** : résultats et historique (../Annexes_laboratoire/T04_RESULTATS.md). Aucune vraie clé, rotation ou revue GitHub démontrée.

Fiche et traçabilité

Chaque fiche en annexe contient objectif, date/versions/comptes, prérequis, étapes, attendu/observé, pièces, statut, diagnostics/retests, conclusion bornée et reproduction. L'opérateur est l'automatisation Codex ; l'appropriation personnelle reste à réaliser. Le cas E/V, les scores et les actions ne sont pas automatiquement modifiés par les tests. Les cibles demeurent conditionnelles.

7. H01 - Observation historique du stage Tanger Med

Nature : lecture d'un document utilisateur réel, pas reproduction du test.

Le rapport de stage fourni décrit une chaîne ClamAV/YARA/CAPEv2/Wazuh sur des ordinateurs personnels et des VM, avec Sysmon et Tailscale.

Repères vérifiés dans l'exemplaire fourni : section 1.5 « Périmètre et exclusions », page PDF 19 ; chapitre 5 « Tests, validation et résultats », pages PDF 55 à 61 ; section 6.1 « Répartition collaborative », pages PDF 62 à 63. Les intitulés permettent de retrouver les passages si une autre version du rapport est utilisée.

Le rapport décrit notamment un essai avec calc.exe le 24 août 2026 et un script PowerShell bénin contenant des commentaires déclenchant un motif YARA. Il présente les événements Wazuh, l'analyse des faux positifs et les limites des essais.

Conclusion utilisable

Le rapport documente une intégration de laboratoire et l'observation de résultats SIEM pour les scénarios décrits. Il permet d'expliquer une chaîne de preuves : fichier, empreinte, tâche sandbox, rapport, événement et décision.

Conclusions non établies par H01

H01 ne démontre pas un déploiement sur les systèmes de TMPA, un taux de détection, une analyse sur un corpus de malwares réels, les quatre nouveaux tests T, la conformité d'un contrôle de toute une organisation ou une expérience opérationnelle complète d'analyste SOC.

Les contributions sont collectives. Anas doit distinguer ses scripts d'orchestration, son intégration API et son travail Wazuh des installations principalement réalisées par son partenaire.

Le dossier de stage n'est pas recopié dans le portfolio public : ses captures et données doivent être examinées avant toute publication.

Source éditable : Projet_1_SSI/07_profil_NIST_CSF_2.md

Projet 1 - Profil actuel et cible NIST CSF 2.0

Cas pédagogique simulé - version 1.0 - 7 octobre 2026

Périmètre

Ce profil couvre treize sous-catégories sélectionnées pour les risques du cas. Les résumés des résultats attendus sont reformulés. Les mesures et les pièces sont propres à l'exercice.

Les états actuels proviennent de justificatifs simulés. Les états cible sont proposés. Le dossier produit pendant l'étude est distingué de son adoption par la PME : écrire une PSSI ne démontre pas qu'elle est approuvée, diffusée ou appliquée.

Profil

Lecture du tableau par entrée : tous les champs sont conservés.

Sous-catégorie : GV.RR-02

Résultat attendu, résumé : Responsabilités SSI explicites et exercées
État actuel du cas : Rôles informels
Pièce : E10
Cible proposée et écart : Propriétaires, pilotes et autorités validés
Action ou vérification : Approbation de la gouvernance du document 01

Sous-catégorie : GV.PO-01

Résultat attendu, résumé : Politique adaptée au contexte et appliquée
État actuel du cas : Politique approuvée non démontrée
Pièce : E10
Cible proposée et écart : PSSI approuvée, diffusée et suivie
Action ou vérification : Document 05, puis preuves de diffusion et d'application

Sous-catégorie : GV.RM-06

Résultat attendu, résumé : Méthode commune d'appréciation des risques
État actuel du cas : Méthode préalable non fournie
Pièce : E10
Cible proposée et écart : Méthode définie, validée et utilisée
Action ou vérification : Document 02 ; revue métier et DG

Sous-catégorie : ID.AM-02

Résultat attendu, résumé : Inventaire des logiciels, services et systèmes
État actuel du cas : Inventaire initial incomplet
Pièce : E01
Cible proposée et écart : Services du périmètre couverts et propriétaires identifiés
Action ou vérification : Validation et maintenance du document 01

Sous-catégorie : ID.RA-05

Résultat attendu, résumé : Analyse de menaces, faiblesses, vraisemblance et impacts
État actuel du cas : Analyse initiale non démontrée
Pièce : E10
Cible proposée et écart : Scénarios documentés avec hypothèses et limites
Action ou vérification : R01 à R12 ; validation des cotations

Sous-catégorie : ID.RA-06

Résultat attendu, résumé : Traitements choisis et suivis
État actuel du cas : Pas de suivi initial fourni
Pièce : E10
Cible proposée et écart : Actions, pilotes, échéances et décisions traçables
Action ou vérification : M01 à M12 et preuves de clôture

Sous-catégorie : PR.AA-03

Résultat attendu, résumé : Authentification des utilisateurs et services
État actuel du cas : MFA partiel, comptes existants
Pièce : E02
Cible proposée et écart : Authentification adaptée, exceptions examinées
Action ou vérification : M01, T01

Sous-catégorie : PR.AA-05

Résultat attendu, résumé : Droits nécessaires, gérés et revus
État actuel du cas : Compte partagé et accès de départ maintenu
Pièce : E02/E07
Cible proposée et écart : Droits nominatifs et retrait effectif
Action ou vérification : M01/M07, procédure A

Sous-catégorie : PR.DS-11

Résultat attendu, résumé : Sauvegardes protégées et testées
État actuel du cas : Jobs déclarés, restaurabilité non démontrée
Pièce : E04
Cible proposée et écart : Restauration et protection vérifiées
Action ou vérification : M03, T03

Sous-catégorie : PR.PS-04

Résultat attendu, résumé : Journaux produits et disponibles pour la surveillance
État actuel du cas : Événement pilote et couverture limitée
Pièce : E03
Cible proposée et écart : Sources prioritaires et accès aux journaux examinés
Action ou vérification : M04, T02

Sous-catégorie : DE.CM-09

Résultat attendu, résumé : Surveillance des équipements, logiciels et données
État actuel du cas : Pilote sur une partie des équipements
Pièce : E03
Cible proposée et écart : Surveillance adaptée, lacunes identifiées et revue réelle
Action ou vérification : M04 ; suivi de couverture et traitement des alertes

Sous-catégorie : RS.MA-01

Résultat attendu, résumé : Réponse exécutée et coordonnée avec les tiers concernés
État actuel du cas : Plan et exercice non fournis
Pièce : E10
Cible proposée et écart : Plan testé dans un exercice et interlocuteurs identifiés
Action ou vérification : Procédure C ; exercice distinct à réaliser

Sous-catégorie : RC.RP-03

Résultat attendu, résumé : Intégrité des moyens de restauration vérifiée avant usage

État actuel du cas : Vérification non démontrée

Pièce : E04

Cible proposée et écart : Copie et moyens de reprise examinés avant restauration

Action ou vérification : M03 ; T03 limité à son échantillon

Interprétation

Les six fonctions Govern, Identify, Protect, Detect, Respond et Recover sont représentées. Leur présence ne signifie pas couverture complète du CSF.

Le profil ne calcule pas de moyenne « Govern 2/5 » ou « Detect 4/5 ». Les Tiers NIST ne sont pas utilisés comme notes par contrôle. La cotation V × I du registre appartient à une autre méthode et ne doit pas être mélangée au profil.

Une cible est satisfaite seulement lorsque son résultat et les preuves attendues sont établis pour le périmètre annoncé. Un document nouvellement écrit peut améliorer la conception sans démontrer le fonctionnement.

Références

NIST CSF 2.0, annexe A, profils organisationnels.

Source éditable : Annexes_laboratoire/INVENTAIRE_LABORATOIRE.md

Inventaire du laboratoire et modifications

Version 1.1 - opérations réelles du 07/10/2026. Horodatages techniques en UTC.

Exécution automatisée par Codex sur le poste personnel d'Anas. Les preuves sont réelles ; elles ne décrivent ni Atlas Services ni SupportCloud. Les pièces E/V restent simulées.

Inventaire initial en lecture seule

Pièce : inventaire_initial.json (preuves/INVENTAIRE/inventaire_initial.json), relevé 2026-10-07T19:28:39.6728628Z.

- Windows 11 Professionnel, version 10.0.26300 ; processeur 11th Gen Intel(R) Core(TM) i5-1135G7 @ 2.40GHz, quatre cœurs et huit processeurs logiques.
- Mémoire visible : 19.73 Gio ; libre lors du relevé : 9.28 Gio.
- Volume C libre lors du relevé : 44.17 Gio. La mémoire et l'espace libre varient pendant l'usage.
- Git 2.48.1 ; VirtualBox 7.1.10r169112 ; agent Wazuh 4.14.6 installé, service WazuhSvc actif.
- Quatre VM enregistrées : Kali, Metasploit Ubuntu, Metasploit Windows et Windows 11 Forensic ; aucune VM en cours. Leur fonctionnement et leurs identifiants ne sont pas vérifiés.
- Metasploit Ubuntu est arrêtée, configurée avec 2 Gio, 2 CPU, NAT et réseau interne ; redirection SSH sur 127.0.0.1:2222. Aucun démarrage ni changement n'a été effectué.
- WSL indique qu'il n'est pas installé. Aucune distribution Linux utilisable n'est démontrée.
- Java, Docker et Keycloak n'étaient pas dans PATH ; l'examen des répertoires et des logiciels n'a pas identifié de composant réutilisable pour T01. Cela n'est pas un inventaire exhaustif de tout le disque.

- Inventaire initial non élevé : accès refusés. Inventaire élevé ultérieur réussi : destination Wazuh 192.168.56.10:1514/TCP, canaux et audit relevés, serveur injoignable. Relevé élevé (preuves/INVENTAIRE/inventaire_eleve.json).
- Adresses privées relevées pour Wi-Fi et interfaces virtuelles ; aucune recherche de cibles de stage ou d'entreprise. La destination est le réseau host-only VirtualBox du laboratoire ; aucun système externe n'est utilisé.

Modifications effectivement effectuées

Modification	Périmètre	Trace et réversibilité
Copie intégrale de référence	18 Markdown et CV cible	reference_v1_20261007T192733Z ; empreintes REFERENCE_MANIFEST.json ; original CV cible conservé
Nouveau dépôt Git	execution_20261007T192733Z/T04_secrets_git	Deux commits, identité Git locale example.invalid ; aucun distant
Archive et restauration	execution_20261007T192733Z/T03_sauvegarde_restauration	Trois fichiers artificiels, copie ZIP, restauration distincte ; originaux conservés
Keycloak et Java portables	T01_acces_mfa	Keycloak 26.8.0 et Temurin 25.0.4.1+1 ; SHA-256 téléchargements vérifiés ; aucune installation système Java
TLS et restriction d'écoute	Keycloak	127.0.0.1:18443 uniquement ; HTTP arrêté ; certificat local 30 jours, clé privée sous ACL restreintes
Identités et politique IAM	Realm grc-lab dédié	LAB-ADMIN, LAB-LECTEUR, TOTP obligatoire à l'inscription ; LAB-RECOVERY master pour mise en place/récupération locale
Protection des secrets de laboratoire	Dossier T01	Héritage ACL retiré ; utilisateur courant, SYSTEM et Administrateurs autorisés ; secrets exclus de la livraison
Dépendances de test HTTP	python_deps dédié	requests 2.34.2, beautifulsoup4 4.15.0 ; notice de reproduction
Inventaire élevé et événement T02	PowerShell	UAC initialement annulée puis acceptée ; compte LAB-GRC-EVT créé puis désactivé, échec 4625 enregistré ; configuration/audit Windows préservés
Nouvelle VM de gestionnaire	VirtualBox, work/T02	Ubuntu officiel vérifié, image 20 Gio, 2 Gio RAM ; variantes de CPU/horloge/firmware documentées ; snapshot initial préservé

État final T02 et modifications du gestionnaire

Gestionnaire Wazuh 4.14.8-1 actif et agent 001 actif observés ; source, réception et alerte 60122 concordantes. Retest VM réussi avec EFI, HPET actif, 2 CPU, KVM, SATA deux ports. URI des dépôts Ubuntu passées à HTTPS et IPv4/timeout/retry bornés ; archives JSON activées dans le nouveau gestionnaire. Enrôlement automatique de l'agent existant, sans édition manuelle de la destination Windows ni de client.keys ; clé client non exportée. Configuration/droits et paramètres examinés, sans démonstration de 90 jours. Les essais BIOS, l'erreur d'encodage du harnais, la tentative sous verrou dpkg et les retests restent visibles. QEMU n'a pas été installé. Voir T02-P01/P03/P04/P05/P05b/P06 et la fiche.

Conservation et partage

Les distributions portables, la VM et les secrets restent dans work. La livraison contient seulement scripts sans secrets, preuves sélectionnées, archive de tickets artificiels et documents. Aucun binaire de stage, certificat privé, seed TOTP, jeton ou mot de passe n'est intégré. Les données sont conservées pour la reproduction ; aucun nettoyage destructif n'a été effectué.

Source éditable : Annexes_laboratoire/T01_RESULTATS.md

T01 Habilitations MFA et sessions

Version 1.1 - opérations réelles du 07/10/2026. Horodatages techniques en UTC.

Exécution automatisée par Codex sur le poste personnel d'Anas. Les preuves sont réelles ; elles ne décrivent ni Atlas Services ni SupportCloud. Les pièces E/V restent simulées.

Statut : RÉUSSI dans le périmètre des deux identités du realm grc-lab.

Objectif et protocole

R01 / M01 / C01 ; repères 8.2 et 8.5 ; protocole 1.1. Contrôler des autorisations positives et négatives, un MFA imposé et la révocation. Les critères initiaux restent conservés dans la référence 1.0.

Environnement et prérequis vérifiés

Keycloak 26.8.0, Java Temurin 25.0.4.1+1, Windows du relevé. Service HTTPS local 127.0.0.1:18443, certificat vérifié par le client HTTP. Realm dédié, comptes LAB-ADMIN et LAB-LECTEUR ; aucun compte personnel utilisé. Opérateur : scripts Codex. Les mots de passe, le seed et les tokens ne figurent pas dans les pièces.

Étapes et résultats

Sous-critère	Attendu	Observé	Preuve
Rôles et règle	Droits distincts et enrôlement OTP obligatoire	realm-admin pour administrateur ; query-users/view-users pour lecteur ; CONFIGURE_TOTP enabled/defaultAction	T01-P01_regles_roles.json (preuves/20261007T193900Z/T01-P01_regles_roles.json)
Fonction du lecteur	Lecture autorisée	GET users HTTP 200	T01-P02_autorisations.json (preuves/20261007T193900Z/T01-P02_autorisations.json)

Sous-critère	Attendu	Observé	Preuve
Administration par lecteur	Refus	PUT realm HTTP 403	T01-P02_autorisations.json (preuves/20261007T193900Z/T01-P02_autorisations.json)
Administration par administrateur	Modification permise	PUT realm HTTP 204	T01-P02_autorisations.json (preuves/20261007T193900Z/T01-P02_autorisations.json)
Nouvelle session et mot de passe seul	Challenge OTP ; aucun token	Nouvelle session HTTP ; formulaire OTP atteint, puis arrêt sans fournir de code	T01-P03_mfa.json (preuves/20261007T193900Z/T01-P03_mfa.json)
Mauvais second facteur	Refus	Retour au formulaire OTP ; aucun token délivré	T01-P03_mfa.json (preuves/20261007T193900Z/T01-P03_mfa.json)
Second facteur correct	Connexion valide	Token endpoint HTTP 200 après authentification TOTP et échange de code OIDC avec PKCE	T01-P03_mfa.json (preuves/20261007T193900Z/T01-P03_mfa.json)
Chemins mot de passe alternatifs	Aucun token sans OTP	grc-evidence et admin-cli : HTTP 400 sans access_token	T01_chemins_alternatifs.json (preuves/20261007T193900Z/T01_chemins_alternatifs.json)
Révocation	Session supprimée et réutilisation refusée	2 sessions avant ; 0 après ; refresh HTTP 400 invalid_grant ; SSO login_required ; ancien access token API HTTP 401	T01-P04_revocation_recuperation.json (preuves/20261007T193900Z/T01-P04_revocation_recuperation.json)
Récupération et exceptions	Configuration et limites examinées	Pas de mail ni codes de récupération ; master LAB-RECOVERY est une exception locale identifiée ; pas de procédure organisationnelle validée	T01-P04_revocation_recuperation.json (preuves/20261007T193900Z/T01-P04_revocation_recuperation.json)

Le reader exerce une fonction de consultation administrative native de Keycloak. Ce n'est pas un test d'un outil de tickets Atlas Services. Les dates exactes, versions et réponses serveur sont dans les exports JSON.

Anomalies correction et retests

Diagnostics réels conservés (preuves/INVENTAIRE/T01-D01_diagnostics.txt) : dépendance HTTP absente, cookies Secure incompatibles avec l'essai HTTP, redirections d'action obligatoire et lecture de la clé manuelle. Corrections : dépendances isolées, TLS local, gestion correcte du formulaire et du Base32. Aucun faux indicateur MFA, suppression de cookie Secure ou contournement de l'authentificateur n'a été utilisé.

Les dossiers datés précédents sont conservés ; le retest final est 20261007T193900Z. Ses exports établissent les refus et autorisations attendus. Les corrections du harnais ne prouvent pas une vulnérabilité de Keycloak.

Conclusion d’audit et limites

Les deux rôles et le MFA TOTP fonctionnent dans le chemin testé ; la session SSO et son renouvellement sont refusés après révocation. L’ancien access token est aussi refusé par l’API native observée. Cela ne démontre pas la révocation immédiate des JWT dans toutes les applications tierces.

TOTP est produit automatiquement à partir du secret réellement délivré par Keycloak. Le mot de passe et ce seed se trouvent sur le même poste de test : aucune séparation matérielle des facteurs, résistance au phishing, récupération par téléphone ou disponibilité d’entreprise n’est démontrée. L’exception master est explicitée, la récupération documentée mais son exercice complet n’est pas réalisé. Le mode start-dev/H2 et le certificat local ne constituent pas une architecture de production.

M01, les risques et les pièces E/V restent dans leur état simulé. Reproduction : prepare_keycloak.py, start_keycloak.py, test_keycloak.py ; voir la notice. Le script crée de nouvelles pièces datées et réutilise le realm dédié uniquement.

Source éditable : Annexes_laboratoire/T02_RESULTATS.md

T02 Événement collecte et SIEM

Version 1.1 — opérations réelles du 7 octobre 2026 ; dates techniques UTC. Opérateur : scripts Codex sur le poste personnel.

Statut : PARTIEL. Source → réception Wazuh → alerte prouvées ; configuration/droits examinés ; conservation opérationnelle et fonctionnement sur 90 jours non démontrés.

Objectif et périmètre

R04 / M04 / C02, repères 8.15 et 8.16, protocole 1.1. Suivre un échec de connexion contrôlé depuis Windows jusqu’au gestionnaire et à sa règle ; examiner les sources, accès et conservation. Atlas Services et SupportCloud demeurent fictifs et leurs actions ouvertes.

Source : Windows 11 Professionnel DESKTOP-3SQ1K5Q, agent Wazuh 4.14.6 ; compte artificiel LAB-GRC-EVT. Gestionnaire : nouvelle VM GRC-Wazuh-T02-20261007, Ubuntu 24.04.5 LTS, noyau 6.8.0-142-generic, paquet wazuh-manager 4.14.8-1. Deux CPU, 2 Gio, disque 20 Gio, NAT et host-only 192.168.56.10. Accès SSH à clé par 127.0.0.1:22022 ; pas d’indexer, Filebeat ou dashboard installés.

L’alias historique de l’agent est TMED-POC-HOST (ID 001), mais l’événement vient du poste personnel DESKTOP-3SQ1K5Q. Cet alias ne désigne pas une cible de production Tanger Med. L’adresse agent 192.168.56.1 est celle du host-only Windows. Le réseau et les quatre VM préexistantes ont été inventoriés ; aucune VM initiale n’a été lancée ou modifiée.

Prérequis et étapes réelles

- Inventaire initial en lecture seule, refus d’accès non élevé et UAC initialement annulée ; diagnostics conservés, puis UAC acceptée pour lecture Security/configuration et compte de test.
- Agent initial actif mais serveur inaccessible. Destination Windows 192.168.56.10:1514/TCP conservée ; canaux Application/Security/System et deux sources déjà configurées identifiés. Audit de connexion succès/échecs déjà actif ; aucun changement d’audit.
- LAB-GRC-EVT créé avec mot de passe aléatoire non affiché. Un LogonUser avec mot de passe incorrect : false/Win32 1326. Source Security 4625 recherchée sur le compte et la période ; compte désactivé en finally.

- Gestionnaire minimal préparé à partir d'une image Ubuntu officielle datée du 26 septembre, SHA-256 attendu/observé identiques. Snapshot avant les corrections, clés SSH privées et images conservés sous ACL dans work.
- Les variantes BIOS ont montré des pertes SSH, retard d'horloge et kernel panic IO-APIC/timer. Le retest EFI avec HPET actif, 2 CPU, KVM et SATA limité à deux ports a permis un démarrage stable, puis l'installation du gestionnaire.
- Dépôts Ubuntu HTTP injoignables, HTTPS testé 200 ; URI passées en HTTPS et IPv4/timeout/retry bornés dans la VM dédiée. Dépôt Wazuh signé accessible ; paquet installé par cloud-init. Un essai manuel concurrent a rencontré le verrou dpkg et n'a pas été forcé. L'installation existante a été laissée se terminer.
- Archives JSON activées dans le gestionnaire (<logall_json>yes). Service actif et agent ID 001 actif. L'agent personnel s'est enrôlé auprès du nouveau serveur ; aucune édition manuelle de ossec.conf ou client.keys Windows. L'empreinte de la clé client n'a pas été relevée ni publiée.
- Recherche dans archives.json et alerts.json sur LAB-GRC-EVT et 4625. Sept champs source/gestionnaire rapprochés exactement ; alerte retrouvée sur le même record. Revue POSIX et paramètres de conservation, sans suppression de traces ni injection de règle artificielle.

Attendu et observé

Sous-critère	Attendu	Observé	Preuve
Source/règles de collecte	Hôte, version, canaux, audit et destination identifiés	Source et configuration relevées ; audit existant, canal Security comprend cet événement	T02-P01 source (preuves/20261007T195320Z/T02-P01_source.json)
Échec contrôlé	Tentative refusée sur compte dédié	LAB-GRC-EVT, API false, erreur 1326, 4625	T02-P02 (preuves/20261007T195320Z/T02-P02_evenement_local.json)
Événement local	Compte, hôte, ID, record et UTC identifiés	Record 2204782, 2026-10-07 T19:53:20.9715351Z, statut 0xc000006d/0xc000006a	T02-P02
Gestionnaire/agent	Service et agent réellement connectés	4.14.8-1 actif, agent 001 actif	T02-P01 gestionnaire (preuves/20261007T202438Z/T02-P01_gestionnaire.json)
Réception	Même événement et équipement	Archives JSON ; sept champs source/gestionnaire identiques	T02-P03 (preuves/20261007T202438Z/T02-P03_reception.json), T02-P06 (preuves/20261007T202438Z/T02-P06_rapprochement.json)
Alerte	Règle applicable observée	Règle native 60122, niveau 5, « Logon Failure - Unknown user or bad password », même record	T02-P04 (preuves/20261007T202438Z/T02-P04_alerte.json)
Accès	Droits et protection examinés	Dossiers 750, fichiers 640, groupe wazuh ; lecture labgrc sans sudo refusée ; sudo permet accès et modification	T02-P05 (preuves/20261007T202438Z/T02-P05_droits_conservation.json), P05b (preuves/20261007T202438Z/T02-P05b_parametres_retention.json)
Conservation	Paramètres et durée réellement vérifiés	Fichiers du jour, JSON/rotation/compression relevés ; aucune récupérabilité à 90 jours démontrée	T02-P05/P05b ; non démontré pour la durée

Chronologie et portée de la réception

Événement source : 2026-10-07T19:53:20.9715351Z. Réception/alerte Wazuh : 2026-10-07T20:23:19.944+0000. Écart des horodatages : 1798.972465 secondes, environ 29 min 59. L’événement avait été créé avant la disponibilité du gestionnaire puis retrouvé après connexion. Ce résultat ne mesure pas le délai habituel d’alerte, n’atteste pas la synchronisation des horloges pendant toute la préparation et ne prouve pas qu’aucun autre événement n’a été perdu.

Conservation protection et couverture

jsonout_output=yes, alerts_log=yes, logall=no, logall_json=yes, log_alert_level=3. Le relevé montre les fichiers archives/alertes courants et datés du jour. Rotation et compression sont activées. monitord.keep_log_days=31 porte sur les **journaux internes tournés**, d'après la documentation officielle ; ce paramètre n'établit pas à lui seul la durée des archives d'événements. Aucune politique opérationnelle complète de 90 jours n'est validée. Le besoin de 90 jours reste une exigence locale du cas, pas une prescription légale.

Les droits empêchent la lecture du fichier par labgrc sans sudo ; l'opérateur sudo/root reste capable de modifier les traces. Pas de stockage immuable, séparation complète des fonctions, restauration à 90 jours ou preuve de rotation sur plusieurs jours. Une seule source Security et un événement sont démontrés ; les autres canaux configurés et le parc entier ne sont pas validés.

Anomalies corrections et retests

Captures réelles et extraits VBox conservés dans le dossier 20261007T195320Z. Le firmware/HPET et le réseau des paquets ont été corrigés uniquement dans la VM dédiée, puis démarrage, installation et collecte ont été vérifiés. Aucune modification globale de Windows, BIOS hôte ou paramètres de sécurité n'a été réalisée ; l'alternative QEMU envisagée n'a pas été installée.

Une première lecture globale UTF-8 du journal a échoué sur un octet 0xe9 d'une autre ligne. Le harnais lit désormais chaque ligne en binaire, tente UTF-8 puis CP1252 en secours, et sélectionne seulement les champs autorisés du compte de test. La ligne de cet événement est bien UTF-8 ; sept champs restent identiques à la source. Diagnostic export (preuves/20261007T202438Z/T02-D05_diagnostic_export.txt), diagnostic réseau (preuves/20261007T202438Z/T02-D06_diagnostic_reseau.txt), tentative sous verrou (preuves/20261007T202438Z/T02-D06_diagnostic_installer.txt). Les journaux bruts et autres comptes restent privés dans la VM, sans export au portfolio.

Conclusion et reproductibilité

Le parcours Windows → agent → gestionnaire → alerte fonctionne pour cet événement après rétablissement du serveur. Les droits et paramètres sont examinés, mais la conservation longue durée et la couverture restent non démontrées : **T02 partiel**, sans modification du critère pour annoncer une réussite complète. Les tags MITRE et de conformité joints à la règle sont des métadonnées du produit ; ils ne prouvent ni une attaque réelle T1531 ni une conformité réglementaire.

Reproduction : preparer_wazuh.py, inventaire_eleve.ps1, t02_source_windows.ps1 avec compte inexistant LAB-GRC-EVT2 et les deux commutateurs explicites, puis relever_wazuh.py et completer_retention.py. Vérifier la disponibilité avant un nouvel événement ; une lecture Security élevée nécessite UAC. Les nouvelles pièces sont datées et ne remplacent pas les précédentes. Aucun nouveau clic n'a été nécessaire pour retrouver l'événement initial.

Source éditable : Annexes_laboratoire/T03_RESULTATS.md

T03 Sauvegarde et restauration de fichiers

Version 1.1 - opérations réelles du 07/10/2026. Horodatages techniques en UTC.

Exécution automatisée par Codex sur le poste personnel d'Anas. Les preuves sont réelles ; elles ne décrivent ni Atlas Services ni SupportCloud. Les pièces E/V restent simulées.

Statut : RÉUSSI pour trois fichiers artificiels sauvegardés en ZIP et restaurés séparément.

Objectif et environnement

R03 / M03 / C03 ; repère 8.13 ; protocole 1.1. Windows et Python 3.12 du runtime, module standard zipfile, compression ZIP_DEFLATED. Données LAB-001, LAB-002 et LAB-003 ; exécutant automatisé, utilisateur Windows courant. Aucun compte de sauvegarde séparé n'est utilisé.

Prérequis et étapes exécutées

Répertoire dédié créé avec échec si le nom daté existe ; trois objets JSON aux contenus connus ; source et restauration distinctes. Contenus, tailles et SHA-256 consignés avant sauvegarde. Archive créée à 2026-10-07T19:27:35.004494+00:00, empreinte 8070450a97c21799443f873b91558d33acb95bc6f0c4f28f670c8ce7df7afd21. Les chemins d'extraction ont été vérifiés pour rester sous la destination résolue. Les originaux n'ont pas été modifiés.

Sous-critère	Attendu	Observé	Preuve
Jeu attendu	Trois contenus connus et empreintes	LAB-001/LAB-002/LAB-003 consignés avant copie	T03-P01_attendus.json (preuves/20261007T192733Z/T03-P01_attendus.json)
Copie identifiée	Date, périmètre et mécanisme réel	ZIP local, trois entrées, date/empreinte/taille enregistrées	T03-P02_copie.json (preuves/20261007T192733Z/T03-P02_copie.json)
Restauration distincte	Ne pas écraser la source	Dossier restaure séparé, source conservée	T03-P03_comparaison.json (preuves/20261007T192733Z/T03-P03_comparaison.json)
Intégrité	Contenus, tailles et empreintes identiques	3 sur 3 pour les trois comparaisons	T03-P03_comparaison.json (preuves/20261007T192733Z/T03-P03_comparaison.json)
Durée et âge	Mesures réellement obtenues	Restauration 0.003680 s ; copie âgée de 0.032541 s au départ	T03-P04_chronologie.json (preuves/20261007T192733Z/T03-P04_chronologie.json)
Droits accessibles	ACL source, archive et restauration	Sorties icacls conservées ; même utilisateur et même volume	T03-P03_comparaison.json (preuves/20261007T192733Z/T03-P03_comparaison.json)

Comparaison détaillée

Fichier	Octets source et restaurés	SHA-256 identique	Contenu identique
LAB-001.json	118 / 118	070047713cb0a4b279542ca2aa7c3d373a82f7635a7b87ae77d676aaf07a949a	Oui
LAB-002.json	165 / 165	bebc71c8caf652a294b96af87010ebd630a97b075a95d42e27b8535f896d7048	Oui
LAB-003.json	144 / 144	5555992300f17092c607695eb15d2303b7565d010909975a11953d37e4e78ebc	Oui

Anomalies et conclusion

Aucune divergence de données, de taille ou d'empreinte observée. Aucun retest correctif de restauration nécessaire. La copie artificielle est fournie comme pièce ZIP ; aucun fichier original ni restauration n'a été supprimé.

La copie permet de récupérer ces trois fichiers uniquement. Même volume et même utilisateur : absence de séparation des privilèges et du support, pas de stockage immuable ni de copie hors site. Cette faiblesse de résilience demeure explicitement hors du critère de récupération locale ; elle empêche toute conclusion de sauvegarde d'entreprise. Ni SaaS, base de tickets, index ou authentification ne sont restaurés. Durée de quelques millisecondes et copie récente ne prouvent pas RTO huit heures/RPO 24 heures. M03 reste proposée dans le cas.

Reproduction : tests_locaux.py crée une nouvelle source, copie et restauration datées, contrôle la destination ZIP, puis compare les trois critères.

Source éditable : Annexes_laboratoire/T04_RESULTATS.md

T04 Marqueur Git historique et accès locaux

Version 1.1 - opérations réelles du 07/10/2026. Horodatages techniques en UTC.

Exécution automatisée par Codex sur le poste personnel d'Anas. Les preuves sont réelles ; elles ne décrivent ni Atlas Services ni SupportCloud. Les pièces E/V restent simulées.

Statut : RÉUSSI pour un fichier dans un nouveau dépôt Git local et deux commits.

Objectif et protocole

R06 / M06 / C04 ; repères 5.17 et 8.4 ; protocole 1.1. Démontrer qu'une suppression courante ne retire pas le contenu de l'historique. Examiner les ACL locales et expliquer la réaction à une vraie exposition.

Environnement et étapes

Git 2.48.1, Windows, dépôt créé exclusivement sous execution_20261007T192733Z/T04_secrets_git/depot_demo. Identité Git LAB-GRC et adresse example.invalid configurées localement ; aucun dépôt existant modifié, aucun remote. Le compte exécutant est l'utilisateur Windows courant.

- configuration.txt contient uniquement des données artificielles et SECRET-DEMO-NON-UTILISABLE.

- Commit initial réel : 456c91950b48e1401cd872f1b5369d67da1f5d05.
- Marqueur retiré dans le fichier courant et commit réel : 9b7dd80636c691bda4dfb6661cc2016490fcb215.
- git show et git grep exécutés sur HEAD et sur l'ancien commit ; git log, status et remote relevés.
- icacls exécuté sur le dépôt et .git.

Sous-critère	Attendu	Observé	Preuve
Marqueur initial	Présent avant retrait	Présent dans le premier commit	T04-P02_premier_commit.json (preuves/20261007T192733Z/T04-P02_premier_commit.json)
Version courante	Marqueur absent	git grep HEAD code 1 ; git show sans marqueur	T04-P03_historique.json (preuves/20261007T192733Z/T04-P03_historique.json)
Historique	Marqueur toujours lisible	git grep ancien commit code 0 ; contenu retrouvé	T04-P03_historique.json (preuves/20261007T192733Z/T04-P03_historique.json)
Périmètre des accès	ACL locales examinées	icacls dépôt et .git ; pas de distant	T04-P01_perimetre_droits.json (preuves/20261007T192733Z/T04-P01_perimetre_droits.json)
Vraie exposition	Procédure justifiée et limites	Invalidation/rotation requises ; non exécutées avec ce marqueur	T04-P04_conclusion.json (preuves/20261007T192733Z/T04-P04_conclusion.json)

Constat recommandation et procédure applicable

Le retrait de la dernière version conserve le contenu accessible aux lecteurs de l'ancien commit. Un dépôt local n'a pas de rôles GitHub vérifiés ; ses ACL ne démontrent pas l'absence de clones ou de copies déjà accessibles ailleurs.

Pour une vraie clé : identifier sa portée et préserver la preuve ; révoquer/invalider immédiatement l'ancien secret auprès du service ; créer une valeur de remplacement stockée hors du dépôt ; tester l'inefficacité de l'ancien et l'usage attendu du nouveau sans les afficher ; examiner les journaux et les lecteurs ; traiter l'historique, références, tags et copies en coordination avec les utilisateurs autorisés ; revoir les habilitations et la prévention ; documenter la clôture et les limites. Réécrire un historique ne remplace pas l'invalidation et impose un plan de conservation et de synchronisation des copies.

Anomalies limites et reproductibilité

Aucune anomalie du mécanisme Git attendu. La persistance historique est l'observation recherchée, pas un secret réel à corriger. Le dossier conserve ce dépôt comme preuve ; aucune réécriture de son historique.

Un marqueur inoffensif, un fichier et deux commits : pas de rotation réelle, pas de recherche exhaustive de secrets, pas de preuve de rôles de plateforme distante, ni de constat d'exposition de données d'entreprise. M06 reste proposée dans le cas. Reproduction : tests_locaux.py ; chaque exécution crée un dépôt distinct.

Source éditable : Annexes_laboratoire/MATRICE_PREUVES.md

Matrice des preuves et traçabilité

Version 1.1 - opérations réelles du 07/10/2026. Horodatages techniques en UTC.

Exécution automatisée par Codex sur le poste personnel d'Anas. Les preuves sont réelles ; elles ne décrivent ni Atlas Services ni SupportCloud. Les pièces E/V restent simulées.

Les chemins ci-dessous désignent les exports réels de référence finale. Les SHA-256 vérifient l'identité du fichier conservé ; ils n'attestent ni signature indépendante ni immutabilité du stockage. Les exports T01 sont assainis à la création ; les commandes Git et ACL et les objets artificiels T03 sont conservés. Les diagnostics retranscrits indiquent leur nature.

Pièce	Lien	Origine et portée
REFERENCE	REFERENCE_MANIFEST.json (preuves/20261007T192733Z/REFERENCE_MANIFEST.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T03-P01	T03-P01_attendus.json (preuves/20261007T192733Z/T03-P01_attendus.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T03-P02	T03-P02_copie.json (preuves/20261007T192733Z/T03-P02_copie.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T03-P03	T03-P03_comparaison.json (preuves/20261007T192733Z/T03-P03_comparaison.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T03-P04	T03-P04_chronologie.json (preuves/20261007T192733Z/T03-P04_chronologie.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T03	T03_copie_artificielle.zip (preuves/20261007T192733Z/T03_copie_artificielle.zip)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T04-P01	T04-P01_perimetre_droits.json (preuves/20261007T192733Z/T04-P01_perimetre_droits.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T04-P02	T04-P02_premier_commit.json (preuves/20261007T192733Z/T04-P02_premier_commit.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T04-P03	T04-P03_historique.json (preuves/20261007T192733Z/T04-P03_historique.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T04-P04	T04-P04_conclusion.json (preuves/20261007T192733Z/T04-P04_conclusion.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T01-P01	T01-P01_regles_roles.json (preuves/20261007T193900Z/T01-P01_regles_roles.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test

Pièce	Lien	Origine et portée
T01-P02	T01-P02_autorisations.json (preuves/20261007T193900Z/T01-P02_autorisations.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T01-P03	T01-P03_mfa.json (preuves/20261007T193900Z/T01-P03_mfa.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T01-P04	T01-P04_revocation_recuperation.json (preuves/20261007T193900Z/T01-P04_revocation_recuperation.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T01	T01_chemins_alternatifs.json (preuves/20261007T193900Z/T01_chemins_alternatifs.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T01	T01_evenements_assainis.json (preuves/20261007T193900Z/T01_evenements_assainis.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T01	T01_statut.json (preuves/20261007T193900Z/T01_statut.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
inventaire	inventaire_initial.json (preuves/INVENTAIRE/inventaire_initial.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T01-D01	T01-D01_diagnostics.txt (preuves/INVENTAIRE/T01-D01_diagnostics.txt)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
T02-D01	T02-D01_acces_refuses.txt (preuves/INVENTAIRE/T02-D01_acces_refuses.txt)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test
VERIFICATION	VERIFICATION_DOCUMENTAIRE.json (preuves/INVENTAIRE/VERIFICATION_DOCUMENTAIRE.json)	Commande locale / réponse serveur / diagnostic limité ; voir fiche du test

Le fichier MANIFEST_FINAL.json (MANIFEST_FINAL.json) contient taille, date et SHA-256 de chaque pièce finale. Les anciens dossiers T01 conservent les essais et retests ; leurs T01-P01 ne sont pas substitués aux pièces finales ci-dessus. T02-P01/P02 source, P01 gestionnaire, P03 réception, P04 alerte, P05/P05b revue et P06 rapprochement disponibles ; conservation longue durée non démontrée.

Chaîne documentaire du cas

E02 → C01 → R01 → M01 → T01 ; E03 → C02 → R04 → M04 → T02 ; E04 → C03 → R03 → M03 → T03 ; E05 → C04 → R06 → M06 → T04. Ce rapprochement est pédagogique et n’est pas une clôture des actions fictives.

V03 → F01/S01/VM01/G2 et F02/S02/VM02/G2 ; V04 → F03/S03/VM03/G4 ; V05/V08 → F04/S04/VM04/G3 ; V01/V07 → F05/S05/VM05/G5 ; V08 → F06/S06/VM06/G6 ; V02/V08 → F07/S07/VM07/G4 ; V06 → F08/S08/VM08/G1. V09/Q17 reste une assurance transversale non démontrée.

Pièces réelles T02 ajoutées

- T02-D02_preparation_VM.json (preuves/20261007T195320Z/T02-D02_preparation_VM.json)
- T02-D03_console_apres_cpu.png (preuves/20261007T195320Z/T02-D03_console_apres_cpu.png)
- T02-D03_console_hyperv.png (preuves/20261007T195320Z/T02-D03_console_hyperv.png)

- T02-D03_console_initiale.png (preuves/20261007T195320Z/T02-D03_console_initiale.png)
- T02-D03_console_sans_ioapic.png (preuves/20261007T195320Z/T02-D03_console_sans_ioapic.png)
- T02-D04_diagnostics_VM.json (preuves/20261007T195320Z/T02-D04_diagnostics_VM.json)
- T02-P01_source.json (preuves/20261007T195320Z/T02-P01_source.json)
- T02-P02_evenement_local.json (preuves/20261007T195320Z/T02-P02_evenement_local.json)

Exports Wazuh et rapprochement final

- T02-D05_diagnostic_export.txt (preuves/20261007T202438Z/T02-D05_diagnostic_export.txt)
- T02-D06_diagnostic_https.txt (preuves/20261007T202438Z/T02-D06_diagnostic_https.txt)
- T02-D06_diagnostic_installer.txt (preuves/20261007T202438Z/T02-D06_diagnostic_installer.txt)
- T02-D06_diagnostic_reseau.txt (preuves/20261007T202438Z/T02-D06_diagnostic_reseau.txt)
- T02-P01_gestionnaire.json (preuves/20261007T202438Z/T02-P01_gestionnaire.json)
- T02-P03_reception.json (preuves/20261007T202438Z/T02-P03_reception.json)
- T02-P04_alerte.json (preuves/20261007T202438Z/T02-P04_alerte.json)
- T02-P05_droits_conservation.json (preuves/20261007T202438Z/T02-P05_droits_conservation.json)
- T02-P05b_parametres_retention.json (preuves/20261007T202438Z/T02-P05b_parametres_retention.json)
- T02-P06_rapprochement.json (preuves/20261007T202438Z/T02-P06_rapprochement.json)

Source éditable : SOURCES.md

Sources et limites de vérification

Version 1.0 - 7 octobre 2026

Sources officielles

Référence	Source primaire	Utilisation dans le portfolio
SRC01	ISO/IEC 27001:2022	Référence des exigences de SMSI ; distinction entre étude de cas et certification
SRC02	ISO/IEC 27002:2022	Guide de mesures de sécurité ; les mesures retenues répondent aux risques du cas
SRC03	ISO/IEC 27005:2022	Référence de gestion des risques SSI ; notre échelle et nos seuils sont des choix locaux
SRC04	ISO/IEC 27001:2022/Amd 1:2024	Existence de l'amendement relatif au climat
SRC05	Communiqué conjoint ISO/IAF, février 2024	Prise en compte du climat dans l'analyse du contexte et des parties intéressées
SRC06	NIST CSF 2.0, CSWP 29	Vérification des identifiants de sous-catégories utilisés dans les deux projets
SRC07	NIST Organizational Profiles	Comparaison actuel/cible et suivi des écarts
SRC08	NIST SP 1305, guide C-SCRM	Lien entre diligence fournisseur, criticité, exigences et suivi
SRC09	CNDP : transfert de données à l'étranger	Point de vérification du projet d'hébergement et de support à l'étranger
SRC10	BSI : présentation de la révision ISO/IEC 27002	Recoupement public de références de mesures ; support informatif, pas remplacement de la norme

Les résumés du portfolio sont rédigés pour le cas. Les textes normatifs complets ne sont pas reproduits.

Ce qui est vérifié et ce qui reste à vérifier

Les fiches officielles ISO confirment les éditions utilisées et le rôle des trois normes. Les pages et publications NIST consultées confirment les sous-catégories sélectionnées. Le communiqué ISO/IAF documente l'ajout des considérations climatiques.

SRC10 a été identifié dans les résultats publics pour recouper certains repères. Son contenu intégral n'a pas été contrôlé ; il n'est pas utilisé pour affirmer une vérification exhaustive des vingt mesures.

L'intégralité des normes ISO sous licence n'a pas été fournie. Les correspondances de clauses et de mesures sont des repères de travail, avec libellés reformulés. Avant un audit professionnel, un examen de certification ou une déclaration de conformité, relire les textes autorisés et vérifier le référentiel applicable.

La sélection de vingt mesures dans l'extrait de SoA n'est pas une revue complète de l'annexe A. Aucune mesure omise de cet extrait n'est déclarée non applicable.

Le profil NIST est volontairement limité à treize sous-catégories. Il ne constitue pas une couverture de tout le CSF. Aucune note de maturité inventée n'est attribuée au NIST.

Le projet fournisseur utilise en complément huit sous-catégories GV.SC, sans prétendre évaluer toute cette catégorie. Les correspondances ISO et NIST décrivent des rapprochements de travail, pas une certification de couverture.

L'analyse CNDP est limitée au signalement d'un point à examiner : finalités, catégories de données, destinations, accès à distance et formalités applicables. Une certification ISO, un contrat ou une localisation européenne ne démontrent pas à eux seuls la licéité d'un transfert. Aucun dossier CNDP ni avis juridique réel n'a été établi.

Sources internes de l'exercice

Source	Nature	Portée
Contexte Atlas Services	Hypothèse créée pour l'exercice	Effectifs, activités, actifs, contraintes et besoins
E01 à E10	Documents fictifs écrits pour l'atelier	Conclusions documentaires du projet 1
V01 à V09	Documents et déclarations fictifs	Conclusions documentaires du projet 2
Rapport de stage Tanger Med fourni par Anas	Document utilisateur réel	Observation historique H01 exclusivement

Le document réel est « rapport stage.pdf », fourni par Anas. Les sections pertinentes décrivent le périmètre du laboratoire, les essais contrôlés, les faux positifs, la répartition du travail et les limites du prototype.

Aucun certificat, signature, logo de certification, numéro d'accréditation ou preuve fournisseur réelle n'a été fabriqué. V09 est une fiche narrative de vérification d'allégation, pas un faux certificat ISO.

Choix de méthode propres au cas

Les éléments suivants sont des conventions pédagogiques, et non des prescriptions ISO ou NIST : douze risques internes, vingt questions fournisseur, huit risques fournisseur, vingt mesures dans l'extrait de SoA, quatre tests manuels, cotation 1 à 5, seuils d'acceptation, exigences MFA, durées de conservation et délais de remédiation.

Le délai de notification fournisseur de 24 heures est une exigence contractuelle proposée dans l'exercice. Ce document ne le présente pas comme un délai légal marocain.

Sources techniques et nouvelle revue du 07/10/2026

- Keycloak 26.8 OpenJDK, administration et TLS : composant réel, OTP, rôles et sessions ; seules les fonctions testées sont revendiquées.
- Release Keycloak et Temurin 25 : téléchargements officiels ; empreintes attendues et observées dans T01-P01.
- Wazuh Windows log collection, image VM et Microsoft 4625 : source, réception et alerte T02 prouvées ; conservation longue durée non démontrée.
- Python zipfile et Git git-show : mécanismes locaux T03/T04.

Les fiches publiques ISO 27001/27002/27005, CSF 2.0 et SP 1305 ont été revues. Les textes ISO complets restent non fournis ; cette revue ne prétend pas vérifier exhaustivement toutes leurs exigences. Les preuves techniques se trouvent dans la matrice (Annexes_laboratoire/MATRICE_PREUVES.md), séparées de E/V et H01.

- Installation Wazuh manager, journaux et archives, options internes, Ubuntu officiel daté et manuel VirtualBox 7.1 : préparation/diagnostic T02. Paramètres observés séparés d'une preuve de conservation durable.